

GEAR

Gestão, Execução,
Agilidade e Risco

**Framework de governança e gestão de TI
para pequenas e médias empresas**

Andre Victor

Edição editorial 2026.10
2026-10-05

Como ler esta edição

O livro reúne o núcleo, o percurso de adoção, guias de tarefas, indicadores, exemplos e modelos. A documentação modular é a fonte editorial; o manuscrito científico tem protocolo e estrutura próprios.

Comece por escopo e princípios. Para aplicar, use os primeiros 30 dias e selecione um guia conforme o problema. Modelos servem ao registro; fundamentos e fontes explicam as adaptações e seus limites.

GEAR evolui do acervo GP-PME e NEXUS-PME. Práticas e instrumentos locais não constituem certificação. Exemplos são ilustrativos e não comprovam efetividade organizacional. IA é assistência opcional, inclusive no nível máximo de maturidade.

Direitos e distribuição

© 2026 Andre Victor. Todos os direitos reservados. O acesso destina-se à avaliação pessoal conforme LICENSE.md do repositório. Reprodução, distribuição, obras derivadas e uso comercial dependem de autorização escrita ou licença válida nos termos daquele documento. Esta edição não altera suas permissões.

As fontes tipográficas Public Sans e Source Serif 4 conservam suas licenças SIL OFL 1.1. Documentos externos são citados, sem atribuir seus direitos ao autor do método.

Situação da publicação

Edição consolidada do acervo autoral. O registro de publicação documenta revisão, preservação, verificações e limites. A aplicação organizacional continua sujeita a avaliação própria. A autoria, os créditos e a declaração de uso de IA do manuscrito científico permanecem próprios daquele documento.

Sumário

01. Escopo e princípios	5
02. Governança e direção	7
03. Execução e serviços	9
04. Segurança e continuidade	11
05. Primeiros 30 dias	13
06. Preparar a adoção e distribuir as primeiras ações	15
07. Maturidade com evidências	17
08. Fichas de desenvolvimento das práticas	19
09. Fluxogramas de decisão e execução	22
10. Priorizar demandas de TI	26
11. Tratar um incidente	28
12. Testar restauração	30
13. Entregar uma melhoria pequena	31
14. Conduzir uma revisão de direção	32
15. Usar assistência por IA	33
16. Escolher e integrar ferramentas	35
17. Indicadores operacionais	39
18. Indicadores de negócio e comparação da rotina	41
19. Indicadores financeiros e hipóteses	44
20. Comparar uma tarefa com e sem assistência	46
21. Uma adoção ilustrativa	48
22. Cenários fictícios do acervo	50
23. Templates de trabalho	53
24. Registro de responsabilidades	54
25. Decisão e prioridade	55
26. Matriz de impacto e urgência	56
27. PRD curto e registro de aceite	57

28. Plano breve de resposta a incidente	59
29. Risco e continuidade	60
30. Revisão de uma saída assistida por IA	63
31. Registro de maturidade	65
32. Painel de indicadores e decisões	66
33. Inventário de ativos e dependências	67
34. Lista de tarefas e verificação	68
35. Instrução de tarefa e assistência	70
36. Prompts para quatro funções de assistência	71
37. Contratos para etapas de elaboração	73
38. Instruções para revisar requisitos e rotina	76
39. Rever a carteira de iniciativas e serviços	78
40. Registrar dados pessoais e responsabilidades	80
41. Origens, adaptações e evolução	82
42. Como interpretar indicadores das versões anteriores	84
43. Glossário	86
44. Fontes e limites de uso	87

01. Escopo e princípios

GEAR ajuda a direção e o responsável por TI a manter um ciclo de decisão: registrar uma necessidade, avaliar impacto e capacidade, atribuir responsabilidade, executar, verificar a saída e revisar o resultado. O recorte é a TI de pequenas e médias empresas, inclusive equipes internas reduzidas e serviços terceirizados.

Problemas tratados

O framework aborda demandas dispersas, prioridades conflitantes, decisões sem responsável, trabalho iniciado sem capacidade disponível, controles de continuidade sem evidência e benefícios financeiros apresentados sem premissas. Esses são problemas de aplicação do método, não uma afirmação sobre toda PME.

Não substitui gestão contábil, obrigação legal, avaliação especializada de segurança ou um sistema completo de gestão empresarial. Um risco jurídico ou regulatório identificado deve ser encaminhado à competência responsável, em vez de receber uma resposta improvisada de TI.

Princípios de aplicação

1. **Responsabilidade identificada.** Cada demanda e decisão têm executor e autoridade de aprovação. Uma pessoa pode acumular funções; o registro torna esse acúmulo visível.
2. **Adoção proporcional.** Ativar uma prática porque resolve uma necessidade observada. Rever complexidade, capacidade e manutenção antes de ampliar o método.
3. **Evidência antes de conclusão.** Uma política escrita, um backup concluído e um serviço restaurado são evidências diferentes. Registrar a que conclusão cada uma permite chegar.
4. **Fluxo visível.** Mostrar fila, trabalho iniciado, bloqueios e exceções. Um incidente não apaga o histórico do trabalho que interrompeu.
5. **Inspeção e adaptação.** Rever prioridades e hipóteses em uma cadência sustentável. Ajustes de duração e capacidade devem ter motivo registrado.
6. **Assistência opcional.** O núcleo pode ser operado com reunião, quadro e registros. IA pode preparar saídas; pessoas permanecem responsáveis pelas decisões.

Núcleo, aplicação e explicação

O núcleo define termos e invariantes. Os guias explicam tarefas. Templates facilitam o registro. Fundamentos apresentam as adaptações e seus limites. Essa separação atende a necessidades distintas de documentação, seguindo a orientação Diátaxis. **F08**

Uma equipe pode usar software de chamados, planilha ou quadro físico. O suporte escolhido precisa preservar responsável, situação, critério de conclusão e evidência. Operação manual significa independência de uma plataforma de gestão, não ausência de tecnologia para executar backup ou proteger contas.

Situação da evidência

GEAR é uma composição autoral de práticas. Cenários demonstrativos e testes de software comprovam apenas o que efetivamente verificam. Metas de prazo, percentuais de melhoria e faixas de indicadores não são resultados médios esperados nem parâmetros normativos universais.

A avaliação acadêmica prevista utiliza casos sintéticos pareados. Até a produção de dados, o protocolo permanece prospectivo. Uma comparação com referências adaptadas precisa declarar escopo e condições de cada configuração, sem construir alternativas deliberadamente fracas.

Próxima leitura: **Governança e direção**. Para executar: **Primeiros 30 dias**.

02. Governança e direção

Este domínio conecta decisões de TI a necessidades do negócio e a riscos conhecidos. A direção define prioridades e autoriza recursos; o responsável por TI organiza a execução e apresenta evidências. A prática admite papéis acumulados, mas exige que cada decisão tenha uma autoridade identificada.

Avaliar, dirigir e monitorar

O acervo chama o ciclo de **ADM-Lite**: avaliar, dirigir e monitorar. No GEAR, avaliar é examinar situação, alternativas, custos e riscos; dirigir é decidir prioridade, limites e responsabilidade; monitorar é confrontar a decisão com evidências e rever a ação.

Essa sigla local não designa o Architecture Development Method do TOGAF. A correspondência detalhada com ISO/IEC 38500 exige consulta à edição oficial; o conteúdo fechado não foi verificado na pesquisa que sustenta esta edição. A apresentação pública do COBIT oferece evidência de dimensionamento e adaptação da governança, sem validar o instrumento local. **F09**

Papéis e acordos

Função	Responsabilidade	Evidência mínima
Direção ou patrocinador	Autorizar prioridade, recurso e aceitação de risco	Decisão com data e condição de revisão
Responsável por TI	Preparar alternativas e conduzir a execução	Registro de demanda, responsável e situação
Dono do processo de negócio	Explicar impacto e validar a entrega	Critério de aceite e confirmação da saída
Usuário afetado	Informar necessidade e efeito percebido	Solicitação e feedback contextualizados

Um técnico terceirizado pode executar sem poder aprovar orçamento. Um proprietário pode ser também dono de processo. Quando o executor é o aprovador, registrar a limitação e buscar revisão de outra pessoa em ações de maior impacto, conforme os controles já existentes na organização.

Use a **matriz de responsabilidades**. RACI-Lite é um suporte de registro: R executa; A aprova; C é consultado; I é informado. Não precisa criar cargos adicionais.

Matriz de quatro finalidades

A Matriz 4 Quadrantes relaciona iniciativas a receita, custos, experiência e resiliência. Uma iniciativa pode ter finalidade principal e efeitos secundários. A classificação não garante benefício: precisa de hipótese, medida e responsável.

Antes de aprovar, perguntar: qual problema observável será tratado; quem recebe o resultado; que condição indicará conclusão; qual recurso será comprometido; que risco permanece; que

alternativa é viável? Uma proposta sem essas informações volta para refinamento ou tem a lacuna explicitada na decisão.

Revisão de direção

CD-TI Lite é o nome histórico da revisão de direção. Uma reunião quinzenal de 30 minutos é o ponto de partida do método, não uma duração obrigatória para toda empresa. A pauta pode reservar cinco minutos para indicadores, quinze para demandas, cinco para riscos e cinco para decisões. Uma emergência pode exigir uma decisão fora dessa cadência.

Registrar decisão, alternativas consideradas, motivo, responsável, prazo e evidência esperada. Comunicar às pessoas afetadas o que mudou e qual canal usar. O registro de conflito entre negócio e TI evita que uma discordância fique escondida sob um status de tarefa.

Critério de funcionamento

O domínio está operacional quando decisões relevantes têm autoridade, justificativa e acompanhamento, e quando a equipe consegue localizar o acordo vigente. A quantidade de atas produzidas não mede a qualidade da governança.

Para executar: **Conduzir uma revisão**. Modelo: **Decisão e prioridades**.

03. Execução e serviços

Este domínio organiza solicitações, incidentes e melhorias em um fluxo observável. O objetivo é compatibilizar capacidade e prioridade, registrando interrupções e critérios de conclusão. A combinação de práticas é própria do GEAR; não constitui uma implementação integral de Scrum ou ITIL. **F03 F10**

Entrada de demandas

Canal único significa **um registro oficial da fila**, com responsável e situação. Pode receber solicitações por formulário, e-mail ou integração. Um pedido recebido por outro meio deve ser registrado ou encaminhado; não se recusa uma emergência porque chegou por telefone.

Definir quem registra incidentes quando o solicitante não consegue acessar o canal. Informar como pedir ajuda e como acompanhar a resposta. Uma mudança de canal precisa de transição e comunicação para evitar demandas perdidas.

Estados de trabalho

Estado	O que representa	Condição para avançar
A Fazer	Demanda ainda não iniciada	Prioridade, responsável e capacidade acordados
Em Andamento	Trabalho iniciado sob responsabilidade do executor	Saída preparada para verificação
Em Teste	Verificação técnica ou de negócio ainda pendente	Critério de aceite atendido e evidência registrada
Concluído	Saída aceita ou encerramento justificado	Motivo e evidência acessíveis

Bloqueio e suspensão são atributos visíveis do cartão, com motivo e próxima ação. Não transformar trabalho iniciado em tarefa nova nem reiniciar seu relógio para melhorar uma métrica.

Limite de trabalho em progresso

O ponto de partida é **até três itens iniciados por executor**, contando Em Andamento e Em Teste sob sua responsabilidade. Trabalho bloqueado permanece visível e conta enquanto mantém compromisso de capacidade. A equipe pode escolher limite menor ou revê-lo após observar capacidade e filas. Registrar exceções temporárias, motivo e prazo de revisão.

Esse número é um parâmetro local de adoção, sem validação universal. Em equipe de uma pessoa, três cartões no sistema não significam três atividades executadas ao mesmo tempo. A concentração do trabalho deve permanecer explícita.

Cadência e entrega

Usar planejamento semanal curto para selecionar trabalho compatível com a capacidade e fazer uma verificação diária da fila. Revisar ao final do ciclo o que terminou, ficou bloqueado e mudou de prioridade. As durações históricas de 15, 5 e 15 minutos são referências iniciais de agenda.

Uma melhoria pequena pode ser planejada como um piloto de uma ou duas semanas. Definir escopo que caiba no período ou negociar sua alteração; o método não garante que qualquer MVP será concluído em duas semanas. A revisão precisa de usuário ou dono de processo, mesmo quando o desenvolvimento é feito por uma pessoa.

Emergências

A raia rápida atende incidentes com impacto que justifique interrupção. Quem reconhece o incidente comunica a prioridade; o executor registra o trabalho suspenso e concentra a resposta. Se o limite for ultrapassado, documentar a exceção e a capacidade comprometida. Após recuperação, decidir quando retomar o item interrompido.

Um incidente precisa de condição de recuperação e comunicação aos afetados. Resolver o chamado e prevenir recorrência podem produzir tarefas distintas, ligadas pelo histórico.

Para executar: **Priorizar demandas, tratar incidentes e entregar uma melhoria.**

04. Segurança e continuidade

Este domínio relaciona serviços críticos, controles e capacidade de recuperação. O conjunto inicial cobre inventário, identidade e acesso, cópias de segurança e resposta a incidentes. Ele é uma seleção autoral de práticas; não oferece proteção integral nem certificação de conformidade.

O NIST CSF 2.0 reúne seis funções: Governar, Identificar, Proteger, Detectar, Responder e Recuperar. O guia do NIST para pequenas empresas apresenta ações e perguntas aplicáveis a organizações com planos de cibersegurança modestos ou inexistentes. GEAR usa essa referência para organizar cobertura e lacunas. **F01 F02**

Serviço, ativo e dependência

Começar pelo serviço que precisa continuar, identificar seus dados, contas, equipamentos, fornecedores e responsáveis. Priorizar sistemas críticos não equivale a conhecer todos os ativos. O termo histórico “Inventário 80/20” é uma estratégia de início por criticidade, não a prova de que 20% dos ativos representam exatamente 80% do risco ou da receita.

Registrar o que ainda não foi inventariado, o responsável pela ampliação e como novas dependências entram no registro. Contas de nuvem e integrações também podem ser ativos relevantes.

Controles e evidência

Prática	Evidência útil	Limite da conclusão
Inventário	Ativo, serviço, responsável, criticidade e revisão	Lista parcial não demonstra cobertura completa
Identidade e acesso	Contas individuais, acesso necessário, MFA e revisão	Um controle isolado não impede todo comprometimento
Cópias de segurança	Execução, retenção, separação e teste de restauração	Job concluído não prova recuperação do serviço
Resposta	Contatos, autoridade, passos e exercício do plano	Plano escrito não demonstra capacidade sob qualquer incidente

A seleção local deve indicar quais resultados do CSF ela cobre, quais ficam pendentes e qual risco é aceito pela direção. O CSF não prescreve uma implementação única nem valida as metas numéricas do GEAR. **F02**

Recuperação

Definir com o dono do processo quanto tempo o serviço pode ficar indisponível e qual perda de dados é tolerável. Esses requisitos orientam retenção, frequência de cópia e teste. RTO é o objetivo de tempo de recuperação; RPO expressa a perda de dados tolerável em tempo. Registrar também dependências e recursos de restauração.

A regra 3-2-1 é um arranjo de cópias a avaliar, não sinônimo de backup testado. Sincronização de arquivos pode propagar alterações ou exclusões; verificar a retenção e o comportamento da solução antes de chamá-la de cópia recuperável. Um teste de arquivo prova um recorte; a restauração de um serviço exige suas dependências.

Resposta proporcional

O Plano de Resposta a Incidentes identifica quem aciona, decide contenção, comunica e verifica recuperação. Ações concretas dependem do incidente e do ambiente. Não transformar uma lista curta em ordem universal de formatar equipamentos, desligar serviços ou apagar evidências.

Após o incidente, registrar causa conhecida ou hipótese, efeito, decisões e correções. A ausência de causa confirmada deve permanecer explícita. A equipe deve encaminhar investigação especializada quando o problema excede sua capacidade.

Para executar: **Testar restauração e tratar incidentes**. Modelo: **Risco e continuidade**.

05. Primeiros 30 dias

Este percurso ensina a iniciar o GEAR em uma equipe pequena. Ao final, a direção deve conseguir localizar a fila de TI, suas prioridades, os riscos mais urgentes e as evidências disponíveis. Trinta dias são uma janela de planejamento local; não garantem implantação completa nem avanço de maturidade.

Preparar a adoção

O responsável por TI combina com a direção quem aprova prioridades e recursos. Escolhem um processo de negócio para acompanhar, um registro de demandas e um lugar para decisões. Não é necessário comprar uma plataforma. Antes de iniciar, confirmam tempo disponível, acesso aos responsáveis e autorização para os testes previstos.

A **verificação pré-projeto** decide se uma iniciativa específica deve começar: problema, patrocinador, viabilidade, risco e capacidade. É diferente da antiga “Fase Zero” de adoção. Um projeto pode ser recusado enquanto a rotina do GEAR continua funcionando.

Semana 1: tornar o trabalho visível

1. Aplicar o **questionário de maturidade**, registrando evidência e lacunas.
2. Escolher até três problemas prioritários com o dono do processo. Anotar o impacto observado, sem estimar ganhos como se já fossem resultados.
3. Criar a fila: A Fazer, Em Andamento, Em Teste e Concluído. Registrar executor, solicitante, prioridade e aceite em cada item.
4. Comunicar o registro oficial. Uma urgência recebida por telefone deve entrar na fila assim que o atendimento permitir.
5. Aplicar o limite inicial de três itens iniciados por executor. Testes e bloqueios entram na contagem; suspensões conservam histórico.

Evidência: fila com trabalho real e registro de quem decide. Se ninguém puder assumir a aprovação, resolver essa lacuna antes de ampliar o método.

Semana 2: conhecer dependências e recuperação

Mapear primeiro os ativos e fornecedores que sustentam o processo escolhido. Registrar proprietário, dados tratados, acesso, suporte, backup e dependências. Essa priorização por criticidade substitui a interpretação literal de “inventário 80/20”.

Executar um **teste de restauração** autorizado, em ambiente seguro. Definir com o negócio o tempo e a perda de dados toleráveis. Documentar resultado, limitações e correções. Preparar uma orientação para uma dúvida recorrente, verificando-a com alguém que precise usá-la.

Evidência: inventário inicial, teste com resultado e instrução utilizável. Backup diário ou recuperação em 30 minutos só são requisitos se o contexto justificar essas escolhas.

Semana 3: decidir e responder

Preencher o **plano de incidente**, conferir contatos e exercitar um cenário simples. Reunir direção, TI e dono do processo para decidir prioridades, riscos aceitos e recursos. Uma revisão de 30 minutos a cada duas semanas é uma configuração inicial; ajustar quando não permitir decisões suficientes.

Evidência: responsáveis localizáveis, decisão com prazo e risco atribuído. Um documento assinado não comprova que a resposta funcionará; o exercício revela dependências.

Semana 4: verificar e ajustar

Escolher os **indicadores** que respondem às dúvidas reais da equipe. Registrar janela, origem e limitações. Reaplicar a maturidade com evidências da prática; dez respostas positivas não dispensam verificação de continuidade e responsabilidade.

Na revisão, decidir quais práticas manter, simplificar ou ampliar. Registrar próximos responsáveis e prazos. Se uma entrega ou teste não couber na janela, informar o motivo e reagendar, sem certificar uma transição inexistente.

Evidência de conclusão do percurso: comparação entre situação inicial e atual, pendências atribuídas e próxima revisão marcada. O percurso pode terminar com riscos ainda abertos.

Exemplo de um começo possível

Uma empresa registra pedidos de acesso que antes chegavam por mensagens. O primeiro resultado verificável é a visibilidade de solicitante, aprovador e situação. O eventual efeito sobre tempo de atendimento precisa ser medido posteriormente. Consulte o **caso didático** para acompanhar um percurso completo.

Fundamento: adoção proporcional e governança de riscos no NIST para pequenas empresas **F01**; organização de tutorial conforme Diátaxis **F08**. A janela de 30 dias e as semanas são propostas locais do GEAR.

Anterior: **Escopo**. Próxima leitura: **Maturidade**.

06. Preparar a adoção e distribuir as primeiras ações

Use este roteiro quando direção e TI já concordaram em tornar a rotina visível. Ele conserva o início em duas horas e os nove passos dos guias antigos como opções de planejamento. Durações e dias são parâmetros locais; confirmar disponibilidade, permissões e responsáveis antes de usá-los.

Uma preparação de duas horas

O resultado esperado é um primeiro conjunto de registros e pendências. A preparação não comprova implantação, recuperação ou maturidade. Se houver incidente ou risco urgente, sua resposta pode alterar a agenda.

Janela sugerida	Ação	Saída a conferir
Primeiros 30 minutos	Escolher registro oficial e meio alternativo quando indisponível	Canal, responsável por captura e comunicado de transição
Próximos 30 minutos	Criar quadro e registrar demandas conhecidas	Solicitante, executor, situação, prioridade e lacunas
Próximos 30 minutos	Examinar prioridades com autoridade do negócio	Até três problemas escolhidos com motivo e capacidade
Últimos 30 minutos	Preparar contatos e alçadas de resposta	Minuta de PRI, contatos conferidos e pendências atribuídas

Demandas recebidas por telefone ou conversa continuam acessíveis ao registro; uma emergência não aguarda o formulário. Não apagar tarefas por classificação de quadrante. Registrar recusa, adiamento ou pedido de informação com motivo. Contatos não fornecidos ficam pendentes. Imprimir o PRI pode ajudar no acesso durante indisponibilidade, mas seu conteúdo e autoridade precisam ser conferidos.

Limite inicial: até três itens iniciados por executor, incluindo teste e bloqueio sob sua responsabilidade. Uma equipe de uma pessoa concentra a execução em uma atividade de cada vez. Se a captura das demandas não terminar na janela, registrar cobertura e plano de continuação.

Nove passos em uma janela de 30 dias

O percurso detalha os **primeiros 30 dias**. Os intervalos conservam a sequência histórica; alterar a ordem conforme dependências e risco. Segurança não precisa aguardar a segunda semana. Registrar mudança de data com motivo.

Intervalo proposto	Ação	Evidência esperada
Dias 1-2	Aplicar maturidade e discutir problemas observados	Respostas com evidência, lacunas e prioridades atribuídas
Dias 3-5	Organizar quadro e capacidade	Demandas conhecidas migradas; testes e bloqueios visíveis

Intervalo proposto	Ação	Evidência esperada
Dias 6-7	Comunicar registro oficial e alternativa	Pessoas sabem pedir ajuda e acompanhar a situação
Dias 8-10	Preparar orientações recorrentes	FAQ testada por usuário, responsável e revisão combinada
Dias 11-14	Mapear dependências críticas e testar restauração	Inventário inicial, requisitos de recuperação, resultado e limites
Dias 15-18	Conferir e exercitar resposta	Contatos, alçadas, comunicação e lacunas do PRI
Dias 19-21	Rever prioridades com o negócio	Decisões, recursos, responsáveis e próxima verificação
Dias 22-25	Coletar indicadores úteis	Origem, janela, unidade, amostra e lacunas
Dias 26-30	Comparar registros e planejar continuidade	Ações mantidas, ajustadas ou adiadas; próxima revisão

Cinco orientações podem ser um começo para a FAQ, quando houver cinco necessidades recorrentes conhecidas. A quantidade não é critério de conclusão. Testar permissões e instruções de acesso; não fornecer credenciais no documento.

Assistência opcional em cada etapa

TI pode pedir uma minuta de quadro, orientação, PRI, pauta ou relatório a uma ferramenta de IA com dados autorizados. A ferramenta pode organizar evidências fornecidas; não responde maturidade por suposição nem inventa contatos. Toda configuração real e integração exigem autorização, teste e revisão compatíveis com o efeito.

Para indicadores, usar cálculo determinístico e conferir unidades. Para FAQ ou bot, oferecer encaminhamento humano e medir resolução confirmada. O tempo total inclui preparação, conferência e correção. Sem IA, executar o mesmo roteiro com pessoas, quadros e registros.

Encerrar a janela

TI apresenta registros e limitações; dono do processo confirma o que foi verificado; direção decide continuidade e risco. Pendências têm responsável e nova data. Não emitir certificação automática de nível 1 nem exigir DAN, nuvem, IA ou um projeto novo para encerrar a adoção inicial.

Fundamento conceitual de cobertura de riscos: NIST **F01**. Agenda, número de passos e janelas são propostas locais, sem garantia de resultado no período.

Anterior: **Primeiros 30 dias**. Consulta: **Maturidade e comparação da rotina**.

07. Maturidade com evidências

O IM-TI é um instrumento local para discutir a rotina de TI. Ele soma dez respostas binárias, de 0 a 10. Não é escala validada cientificamente, certificação ou comparação confiável entre empresas com contextos diferentes. Seu uso principal é encontrar lacunas e acompanhar a mesma organização ao longo do tempo.

Aplicar o questionário

TI e dono do processo respondem juntos. Marcar 1 somente quando a prática ocorre e existe evidência consultável; marcar 0 quando ausente ou insuficiente. Registrar “não verificado” na observação quando faltar informação, contabilizando 0 provisoriamente. Não excluir perguntas para elevar a pontuação.

Nº	Prática a verificar	Evidência possível
1	Demandas têm registro oficial e responsável	Amostra da fila com solicitante e executor
2	Trabalho iniciado respeita a capacidade definida, incluindo testes e bloqueios	Quadro com testes, bloqueios e exceções
3	Orientações recorrentes são mantidas e verificadas	Instrução revisada por usuário, com responsável
4	Negócio e TI decidem prioridades em revisão registrada	Decisão com motivo, alçada e prazo
5	Melhorias têm problema, escopo e aceite acordados	PRD curto e verificação pelo dono do processo
6	Ativos e dependências críticos estão identificados	Inventário com proprietário e criticidade
7	Recuperação foi testada na janela combinada	Registro de restauração e limitações
8	Acessos críticos são controlados e revistos	Revisão de privilégios, MFA e exceções
9	Indicadores usados têm origem, período e revisão	Registro de dados e decisão vinculada
10	Decisões e mudanças passam por revisão responsável	Aprovação, verificação e correção registradas

Nenhuma pergunta exige chatbot, agente, modelo generativo ou percentual de automação. O nível máximo pode ser alcançado com procedimentos manuais e controles tecnológicos apropriados.

Interpretar sem ocultar lacunas

IM-TI	Nível descritivo	Próxima ação típica
0-2	0: rotina pouco visível	Identificar responsáveis e registrar demandas
3-5	1: organização inicial	Verificar continuidade e critérios de aceite
6-8	2: práticas repetidas	Investigar lacunas e dependências entre práticas
9	3: rotina acompanhada	Rever qualidade das evidências e resultados
10	4: práticas verificadas	Manter a revisão e adequar o método ao contexto

As faixas são convenções locais preservadas para continuidade do instrumento. As perguntas desta edição foram revistas: resultados antigos não são diretamente comparáveis sem reaplicação. As faixas não indicam probabilidade de ataque, retorno financeiro ou superioridade organizacional. Uma organização com pontuação alta e restauração não testada continua exposta.

Decidir uma transição

Comparar a aplicação atual à anterior na mesma janela de evidência. Registrar o que passou a ocorrer, quem verificou e o que permanece incerto. O score pode mudar imediatamente; a **transição sustentada** exige observar a prática na rotina, por um período acordado. Não declarar avanço automático no dia 30.

Selecionar até três ações de melhoria por impacto e capacidade. Manter o resultado por pergunta junto ao total. Se uma resposta for contestada, revisar a evidência e corrigir o histórico, sem apagar a avaliação anterior.

Responsável pela aplicação: TI. Responsável pela validação de efeitos no negócio: dono do processo. Direção aceita recursos e riscos conforme a alçada. Modelo: **Registro de maturidade**.

Para planejar uma melhoria específica, consultar as **fichas por domínio**. Elas preservam a matriz detalhada das versões anteriores como opções de desenvolvimento, sem acrescentar condições ao IM-TI.

Anterior: **Primeiros 30 dias**. Para compreender: **Fundamentos e adaptações**.

08. Fichas de desenvolvimento das práticas

Estas fichas preservam a matriz extensa dos guias anteriores em blocos consultáveis. Descrevem possibilidades de desenvolvimento por domínio, com entradas, saídas e observações. São propostas locais para planejar melhorias; não constituem critérios adicionais de pontuação ou uma escala validada.

O nível descritivo é calculado pelo **IM-TI vigente**. Uma empresa pode ter práticas desenvolvidas de modo desigual. Usar uma ficha quando ela corresponde à lacuna observada, mesmo que o nível do total seja outro. IA é opcional em todas as fichas.

Visão de consulta

Nível descritivo	Foco de desenvolvimento possível	Conferência necessária
0: rotina pouco visível	Identificar responsáveis e o trabalho existente	O que está conhecido e o que falta registrar
1: organização inicial	Tornar fila e controles consultáveis	Se os registros refletem a prática
2: práticas repetidas	Decidir e executar com critérios e evidência	Lacunas de continuidade e alçada
3: rotina acompanhada	Comparar resultados e investigar diferenças	Premissas, limites e efeitos observados
4: práticas verificadas	Adaptar o método às mudanças do contexto	Sustentação das práticas e novos riscos

Ficha 0: conhecer a situação

Governança. Entradas: reclamações, demandas e restrições conhecidas. Ação: identificar quem pode decidir e quais acordos já existem. Saída: responsáveis, prioridades provisórias e lacunas. Observação: ausência de atas não comprova ausência de toda decisão.

Execução. Entradas: pedidos verbais, mensagens e trabalho já iniciado. Ação: reconciliar demandas sem duplicar e atribuir executor. Saída: fila inicial, bloqueios e alcance da captura. Medida possível: quantidade registrada e itens sem responsável.

Segurança. Entradas: serviços, contas, fornecedores e cópias conhecidos. Ação: identificar dependências e risco imediato. Saída: inventário inicial e verificação autorizada a planejar. Observação: desconhecer o backup exige investigar; não permite declarar perda ou probabilidade de ataque.

Assistência opcional. Organizar relatos em minuta com origem, sem preencher informações ausentes. Saída humana equivalente: registro das mesmas evidências.

Ficha 1: organizar a rotina

Governança. Entradas: fila, responsáveis e primeiros dados. Ação: definir alçadas e uma revisão compatível com a necessidade. Saída: decisões atribuídas e próximas verificações. Medida possível: decisões com acompanhamento, sem exigir uma quantidade de atas.

Execução. Entradas: solicitações identificadas e capacidade disponível. Ação: aplicar estados, limite de trabalho e registro oficial; preparar orientação recorrente. Saída: cartões com critério de conclusão e FAQ verificada. Medidas: trabalho iniciado e tempo de fluxo, com lacunas declaradas.

Segurança. Entradas: inventário parcial, acesso e registros de cópia. Ação: conferir privilégios e proteção; distinguir execução de backup e restauração. Saída: cobertura, exceções e teste planejado ou executado. Um job aprovado não prova recuperação.

Assistência opcional. Rascunhar orientação ou triagem, com revisão e encaminhamento humano. Não exigir bot nem 40% de resolução para alcançar o nível.

Ficha 2: repetir e verificar

Governança. Entradas: demandas, indicadores, risco e alternativas. Ação: revisar com direção e dono do processo, usando finalidades de negócio. Saída: decisão, recurso, motivo, prazo e responsável. Medidas: indicadores selecionados com tolerâncias locais, sem mínimos universais de IDSC ou ISU.

Execução. Entradas: solicitações e critérios de impacto, urgência e dependência. Ação: ordenar a fila e verificar entregas. Saída: aceite ou encerramento justificado, bloqueios e exceções de capacidade. Medidas: fluxo e restauração, mantidos separados.

Segurança. Entradas: dependências críticas, requisitos de recuperação e contatos. Ação: testar o escopo autorizado e exercitar o PRI. Saída: duração observada, resultado, limites e correções. RTO é objetivo; duração medida é resultado do teste. Nem trimestre nem 30 minutos são requisitos universais.

Assistência opcional. Reutilizar prompts revisados com contexto autorizado. Saída: proposta rastreável; a decisão continua atribuída a uma pessoa.

Ficha 3: acompanhar efeitos

Governança. Entradas: cenários de custo, benefício e resultados observados. Ação: comparar hipóteses ao ocorrido e decidir recursos. Saída: revisão de investimento e roteiro de melhorias. DAN e COT só entram se ajudarem a decisão; estimativa não comprova retorno.

Execução. Entradas: problema, PRD e condição de retorno. Ação: testar melhoria delimitada com usuário. Saída: piloto verificado e decisão de continuar, ajustar ou encerrar. Medidas: tempo de lançamento, aceite e benefício observado, cada um com origem e período.

Segurança. Entradas: exceções de acesso, vulnerabilidades verificadas e mudanças do serviço. Ação: planejar correções por exposição e capacidade, conferindo configuração e dependências. Saída: correções verificadas e risco residual atribuído. Relatório de scanner isolado não comprova mitigação completa.

Assistência opcional. Elaborar PRD, histórias, código e teste por etapas revisadas. Saída: minuta ou artefato verificado; roteiro de teste não substitui sua execução.

Ficha 4: adaptar com evidências

Governança. Entradas: mudanças de escala, serviço, fornecedor ou estratégia. Ação: rever alçadas, orçamento, dependências e método. Saída: plano atualizado com alternativas e riscos. Não exigir fusão empresarial, arquitetura em nuvem nem DAN abaixo de 0,15.

Execução. Entradas: histórico de capacidade, filas e entregas. Ação: adaptar limites, critérios e cadência, preservando comparabilidade quando possível. Saída: política revisada e acompanhamento. Não exigir TEIA acima de 60% ou qualquer automação.

Segurança. Entradas: testes, incidentes, acesso e obrigações aplicáveis. Ação: revisar cobertura, resposta e recuperação após mudanças. Saída: lacunas tratadas ou riscos aceitos por autoridade apropriada. Não definir excelência por “zero vazamentos” ou “zero paradas”; ausência de registro também pode ser lacuna de detecção.

Assistência opcional. Comparar utilidade, revisão, correção e permissões das ferramentas. Saída: manter, restringir ou retirar a assistência conforme evidências. Procedimentos manuais podem sustentar o nível máximo.

Transformar uma lacuna em ação

1. Vincular a ação a uma evidência ausente ou insuficiente, sem presumir que todo o domínio falhou.
2. Definir responsável, recurso, dependência, prazo e como verificar.
3. Selecionar até três ações compatíveis com a capacidade. Emergências podem mudar a ordem.
4. Executar e registrar resultado, incluindo falha ou limitação.
5. Rever a prática na janela combinada e reaplicar a pergunta correspondente.

As antigas listas de transição passam a ser opções: capturar demandas, controlar trabalho iniciado, verificar FAQ, testar recuperação, conferir PRI, rever prioridades ou testar melhoria. Prompts e agentes só entram quando escolhidos. Uma assinatura registra aprovação; não certifica avanço sustentado.

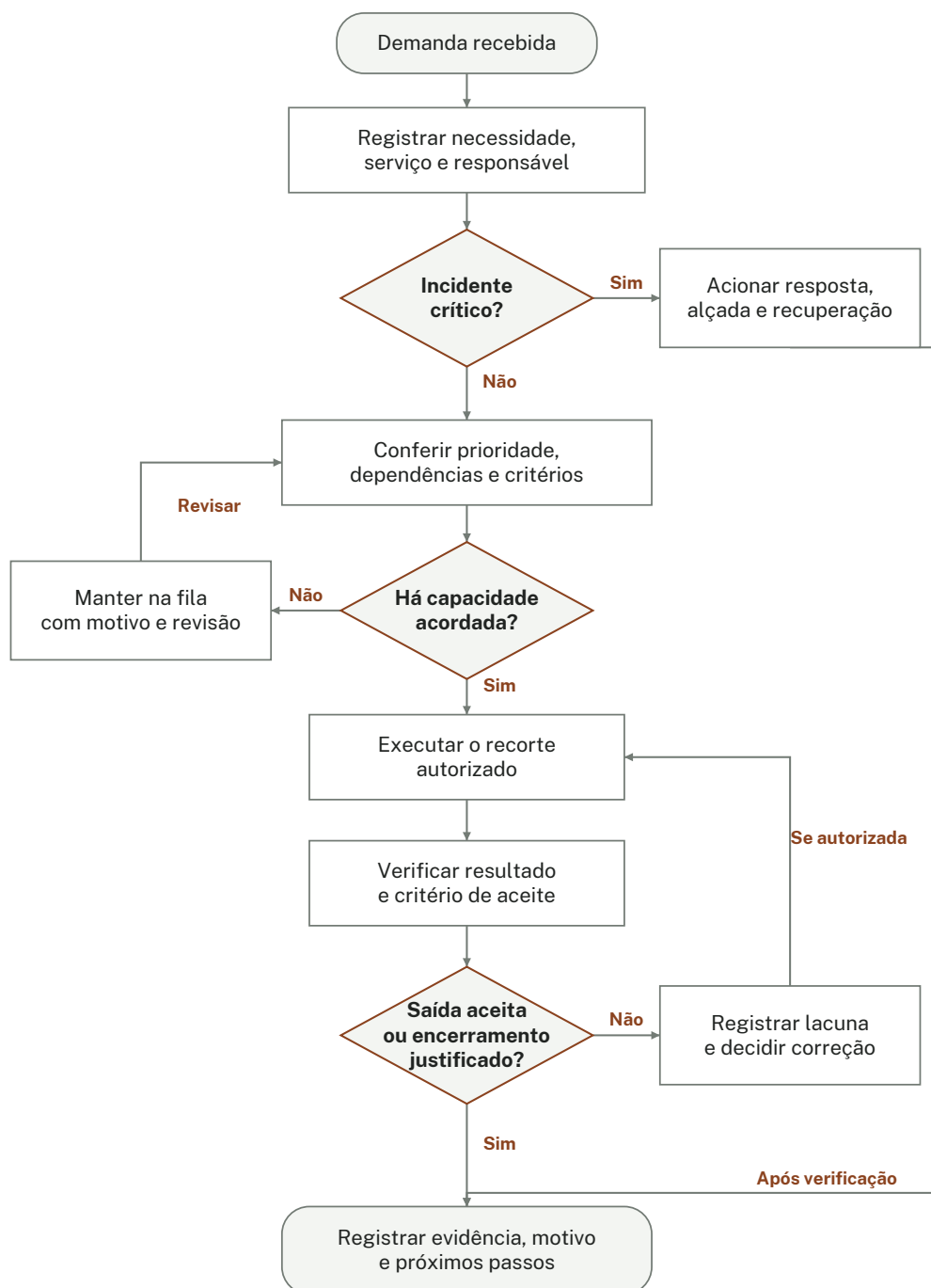
Responsável: TI, com verificação do dono do processo e alçada da direção. Entrada: resultado por pergunta e evidências. Saída: plano de melhoria e histórico preservado. Concluir quando cada ação selecionada tem resultado verificável ou pendência atribuída.

Anterior: **Maturidade**. Modelo: **Registro de maturidade**. Para compreender: **Origens e adaptações**.

09. Fluxogramas de decisão e execução

Os fluxos abaixo tornam visíveis decisão, execução, espera e retorno. Retângulos são ações; losangos são decisões; formas arredondadas delimitam entrada ou encerramento. “Sim” e “não” identificam o caminho escolhido. Eles resumem práticas locais do GEAR, sem substituir os critérios e alçadas dos guias.

Da demanda ao encerramento

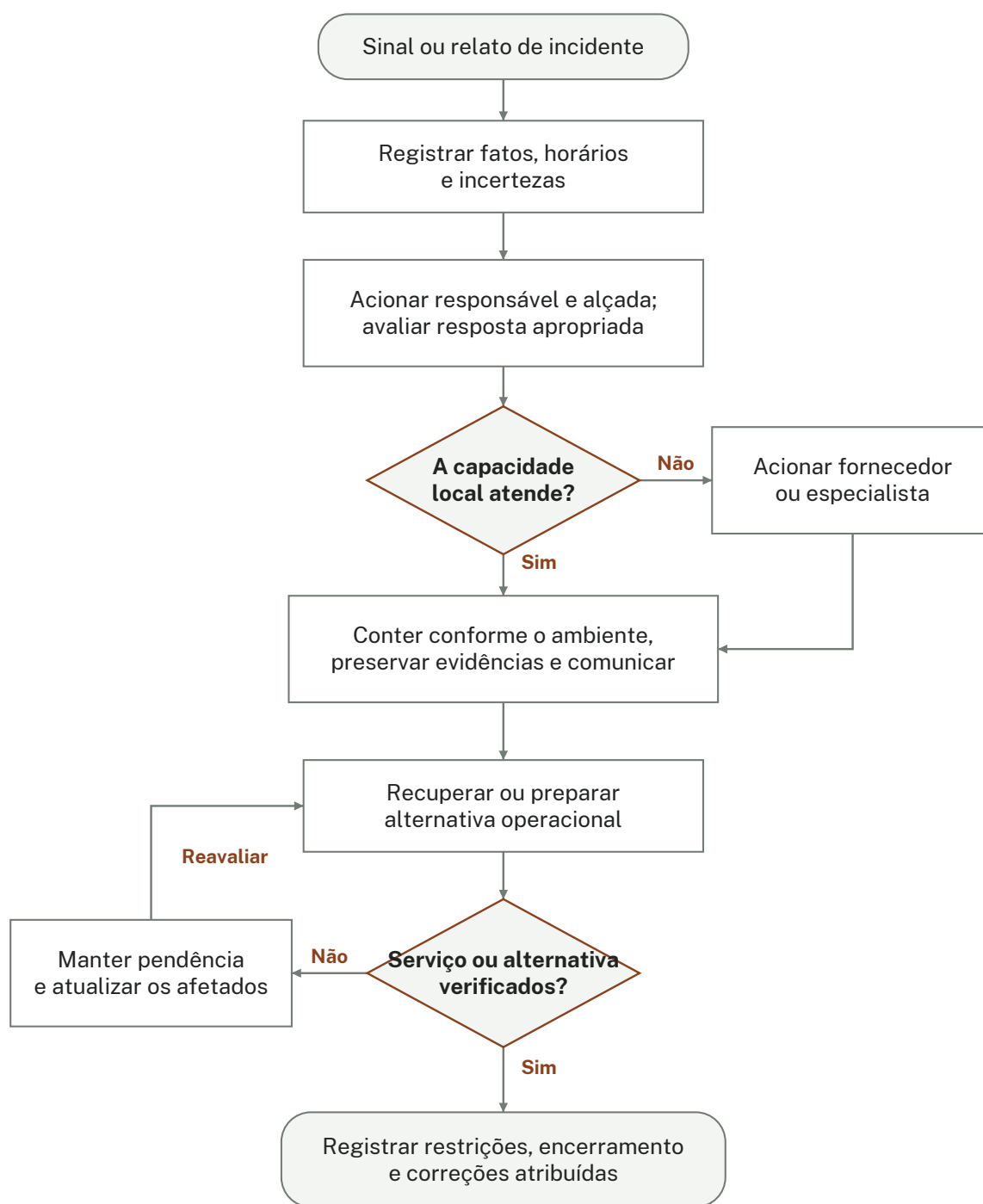


Fluxo de demanda: reconhecer incidente crítico, conferir capacidade, executar, verificar e registrar o encerramento.

1. Receber e registrar necessidade, serviço e responsável. Uma emergência é atendida e registrada assim que viável.
2. Se houver incidente crítico, acionar resposta e autoridade apropriadas. Encerrar somente após a verificação descrita no guia de incidentes.
3. Para a fila comum, conferir prioridade, dependências e critérios. Contar andamento, teste e bloqueio comprometido na capacidade por executor.
4. Se não houver capacidade acordada, manter motivo e revisão na fila. Retomar a decisão quando houver mudança de prioridade, dependência ou capacidade.
5. Executar o recorte autorizado e verificar a saída. Se houver lacuna, registrar e decidir a correção; o retorno à execução depende de autorização e capacidade.
6. Registrar evidência, motivo de encerramento e próximos passos. Cancelamento ou outra forma de encerramento precisa de justificativa, sem se apresentar como entrega aceita.

Bloqueio ou suspensão conserva histórico e relógio; o diagrama não autoriza ocultar trabalho iniciado para liberar WIP. Para critérios completos: **priorizar demandas, execução e serviços e entregar melhoria.**

Resposta e recuperação



Fluxo de incidente: registrar sinais, acionar alçada, verificar capacidade, responder, recuperar e conferir serviço ou alternativa.

1. Registrar fatos, horário e incertezas; acionar responsável e autoridade sem aguardar causa confirmada.
2. Se a capacidade local for insuficiente, acionar fornecedor ou especialista pelos contatos conferidos. A resposta depende do ambiente e da alçada, com preservação de evidências.
3. Comunicar fatos verificados e próxima atualização. Recuperar o serviço ou preparar uma alternativa operacional.

4. Se a verificação com o dono do processo falhar, manter pendência, atualizar os afetados e reavaliar a recuperação. Uma alternativa aceita não significa que o serviço original voltou.
5. Registrar limitações, encerramento e correções atribuídas. Investigar causa e prevenção em tarefas ligadas ao incidente, quando necessário.

O fluxo não prescreve isolamento, desligamento ou formatação universais. Critérios, contatos e obrigação de comunicação permanecem no **guia de incidentes** e no **plano breve**. Fundamentos: NIST **F01**, **F02** e CISA **F12**; a sequência gráfica é uma adaptação local.

As figuras são vetoriais. Na tela pequena, a região permite rolagem horizontal e os passos textuais conservam o conteúdo para leitura. A imagem de rotina diária fornecida pelo usuário orientou as formas e as ramificações; suas atividades não fazem parte do método.

10. Priorizar demandas de TI

Este guia ajuda a transformar pedidos concorrentes em uma fila com decisões e capacidade visíveis. Use quando solicitações chegam por vários meios, a equipe inicia mais trabalho do que consegue encerrar ou o negócio discorda da ordem de atendimento.

Responsável pela preparação: responsável por TI. A direção ou autoridade delegada decide conflitos que comprometem recursos, prioridades de negócio ou risco. Entrada: demandas registradas, capacidade disponível, serviços afetados e acordos existentes. Saída: fila ordenada, itens selecionados, responsáveis e motivos.

Preparar o registro

Para cada demanda, registrar solicitante, necessidade, serviço afetado, consequência de adiar, prazo real, responsável e condição de conclusão. “Urgente” sem consequência identificada é informação insuficiente para decidir prioridade.

Uma solicitação incompleta permanece na fila como “aguardando informação”, com quem fornecerá o dado. Um incidente crítico recebe tratamento imediato e registro assim que viável. O canal único não é uma barreira ao acesso de quem está com o sistema indisponível.

Executar a priorização

1. Separar recuperação de serviço, atendimento recorrente e melhoria planejada. Demandas de naturezas distintas podem exigir critérios e prazos diferentes.
2. Avaliar impacto, urgência e dependências. Usar as quatro finalidades de negócio para explicar valor, sem somar notas arbitrárias como se fossem medidas objetivas.
3. Conferir itens iniciados, incluindo teste e bloqueio. O limite inicial é três por executor; reduzir quando a capacidade disponível exigir.
4. Selecionar trabalho para o próximo ciclo e obter a decisão da autoridade responsável quando houver conflito.
5. Registrar ordem, decisão, responsável e critério de conclusão. Comunicar ao solicitante o próximo passo, inclusive quando a demanda foi adiada.

Tratar exceções

Um incidente com interrupção relevante pode usar a raia rápida. Tornar visível o item suspenso, sua dependência e a revisão de prazo. Não devolvê-lo à fila como se nunca tivesse sido iniciado.

Se há várias emergências, a direção decide qual serviço recebe a capacidade limitada e quem comunica as consequências. Um limite de WIP sozinho não resolve essa escolha.

Exemplo ilustrativo

Uma equipe de uma pessoa recebe pedido de relatório gerencial, erro que impede faturamento e troca de assinatura de e-mail. O incidente de faturamento recebe a primeira resposta porque há serviço indisponível. O relatório fica planejado após confirmar seu prazo e dono do processo. A assinatura entra na fila comum. A ordenação precisa do impacto observado; o exemplo não fixa uma prioridade universal para esses tipos de pedido.

Encerrar

A priorização terminou quando cada item selecionado tem executor e critério de saída, itens adiados têm motivo e a equipe conhece a capacidade comprometida. Na revisão seguinte, confrontar decisão e efeito. Não avaliar sucesso pela quantidade de cartões iniciados.

Modelo: **Decisão e prioridades**. Referência: **Execução e serviços**. Próxima tarefa: **Entregar uma melhoria**.

11. Tratar um incidente

Use quando há interrupção de serviço ou suspeita de comprometimento que exige coordenação. A pessoa que recebe o relato inicia o registro; a autoridade definida no plano decide contenção e comunicação; o executor técnico verifica a recuperação. Entrada: relato, serviços afetados, contatos e plano vigente. Saída: serviço recuperado ou alternativa acordada, decisões registradas e ações posteriores identificadas.

Reconhecer e avaliar

Registrar momento de identificação, sinais observados, serviço e usuários afetados. Distinguir fato de hipótese. “Sistema indisponível” é observação; “ataque de ransomware” exige evidência adicional. A falta de certeza não impede acionar o responsável.

Estimar impacto e comunicar à autoridade competente. Se o caso excede a capacidade local, acionar fornecedor ou especialista conforme os contatos do plano. A pessoa afetada não precisa preencher um formulário inacessível para receber ajuda.

Conduzir a resposta

1. Identificar quem coordena e como a equipe atualizará a situação.
2. Registrar prioridades, trabalho suspenso e exceção de capacidade.
3. Avaliar contenção apropriada ao ambiente e preservar informações necessárias à investigação. Não aplicar formatação ou desligamento como regra automática.
4. Comunicar estado e alternativa operacional aos afetados, evitando declarar causa não confirmada.
5. Recuperar a partir de uma condição conhecida e verificar serviço, dados e dependências com o dono do processo.
6. Registrar horários, decisões, evidências e necessidade de acompanhamento.

As seis funções do CSF articulam governança, identificação, proteção, detecção, resposta e recuperação; elas não oferecem um único roteiro de ações técnicas para todo incidente. **F01 F02**

Verificar recuperação

Confirmar que o processo necessário funciona e que a equipe conhece restrições temporárias. O desaparecimento de uma mensagem de erro não é suficiente para encerrar. Se uma alternativa foi adotada, declarar se o serviço original segue pendente.

O relógio de resolução começa no registro definido para a métrica e termina na condição de encerramento acordada. Registrar também o momento de identificação quando diferente. Não excluir incidentes longos de um indicador sem mostrar o critério.

Rever e prevenir recorrência

Preparar revisão proporcional: o que ocorreu, quais decisões ajudaram, onde faltou informação e qual ação tem responsável. Correção definitiva pode ser uma melhoria vinculada ao incidente. “Causa ainda não confirmada” é uma conclusão válida, com próximo passo.

Modelo: **Plano de resposta**. Próxima tarefa: **Testar restauração**.

12. Testar restauração

Este guia verifica um recorte definido da capacidade de recuperar dados ou um serviço. Use antes de depender de um backup, após alteração relevante da solução e na cadência acordada para o serviço. Responsável técnico prepara o teste; dono do processo valida a saída. Entrada: cópia disponível, ambiente apropriado, autorização, dependências e objetivos de recuperação. Saída: evidência do teste e plano de correção de lacunas.

Definir o recorte

Especificar serviço ou conjunto de dados, versão, momento da cópia, dependências, condição de sucesso e limite do teste. Um arquivo restaurado não demonstra a restauração completa de ERP, identidade, rede e integrações.

Definir RTO e RPO com o negócio. A referência histórica de restauração em 30 minutos não é meta universal; a necessidade do processo e os recursos disponíveis orientam o requisito.

Executar

1. Confirmar acesso à cópia e às chaves necessárias, seguindo as permissões e controles da organização.
2. Preparar ambiente isolado ou autorizado, sem sobrescrever a operação por conveniência do teste.
3. Restaurar o recorte, registrando início, fim, versão e erros.
4. Verificar integridade e funcionalidade com o dono do processo.
5. Comparar tempo e perda de dados com os objetivos acordados.
6. Registrar escopo aprovado, limitações, evidências e correções com responsável e prazo.

Interpretar

“Backup executado” indica execução do mecanismo. “Arquivo restaurado” indica recuperação daquele recorte. “Serviço recuperado” exige verificação das dependências e da funcionalidade definida. Preservar essa diferença na ata e nos indicadores.

Se faltou credencial, a cópia não existia ou o tempo excedeu o objetivo, registrar a falha e rever o plano. Não substituir o resultado por sucesso estimado.

A orientação NIST para pequenas empresas inclui recuperação e ações ligadas à continuidade. A implementação do teste e sua frequência precisam considerar o contexto. **F01**

Modelo: **Risco e continuidade**. Próxima leitura: **Indicadores operacionais**.

13. Entregar uma melhoria pequena

Use para uma alteração de TI com resultado verificável por um processo de negócio. Responsável por TI prepara a solução; dono do processo define e verifica o aceite; direção aprova recursos e riscos conforme a alçada. Entrada: necessidade, situação atual, restrições e capacidade. Saída: mudança verificada, registro de aceite e efeito a acompanhar.

Delimitar

Registrar problema, beneficiário, escopo, exclusões e condição de sucesso em um PRD curto. Uma ou duas semanas podem ser o intervalo de um piloto; se o escopo não couber, reduzir a entrega ou negociar outro prazo. A duração não substitui uma estimativa de capacidade.

Um requisito pode usar “Dado/Quando/Então”: dado um pedido autorizado, quando o relatório é solicitado, então os campos definidos aparecem sem edição manual. Esse exemplo descreve comportamento esperado, não afirma que a solução já foi implementada.

Executar

1. Conferir dados, permissões, integrações e dependências.
2. Definir executor e quem aceitará a saída.
3. Registrar critério de verificação, risco e retorno à condição anterior.
4. Selecionar trabalho compatível com a fila e seu limite.
5. Construir e testar o recorte acordado.
6. Verificar com o usuário ou dono do processo; registrar aceite ou correções.
7. Acompanhar a hipótese de benefício na janela definida.

Aprender com a entrega

Uma solução aceita pode não produzir o benefício esperado. Medir uso, efeito e esforço de manutenção. Se a hipótese falhar, registrar o resultado e decidir adaptar ou interromper, sem reclassificá-lo como sucesso apenas porque houve implementação.

As práticas de inspeção e adaptação são compatíveis com a inspiração ágil; retirar elementos de Scrum impede chamar qualquer ciclo curto de implementação integral desse framework. **F03**

Modelo: **PRD e aceite**. Próxima tarefa: **Conduzir uma revisão**.

14. Conduzir uma revisão de direção

Use para decidir prioridades, recursos e tratamento de risco com base na situação atual de TI. Responsável por TI prepara a pauta; direção ou autoridade delegada decide; dono de processo contribui quando há impacto direto. Entrada: fila, indicadores com contexto, decisões anteriores e riscos. Saída: registro de decisões, responsáveis e próximos pontos de verificação.

Preparar

Reunir dados da mesma janela, itens bloqueados, incidentes relevantes e propostas que exigem decisão. Mostrar a origem de cada informação e o que falta. Uma tabela com três indicadores sem período, amostra e critério de coleta não basta para decidir.

Distribuir o material antes da reunião quando isso for viável. Não preparar dezenas de páginas para uma decisão que cabe em um registro curto. Questões que exigem análise técnica podem receber responsável e prazo fora da reunião.

Decidir

1. Retomar decisões anteriores e suas evidências.
2. Examinar fila, capacidade e conflitos de prioridade.
3. Relacionar propostas às finalidades de receita, custo, experiência e resiliência.
4. Examinar riscos, lacunas e alternativas.
5. Registrar decisão, motivo, autoridade, executor, limite de recurso, prazo e condição de revisão.
6. Comunicar alterações às pessoas afetadas.

Conferir o registro

A ata precisa permitir que uma pessoa ausente entenda a decisão e encontre seu responsável. “A TI deve melhorar” não define saída. “Responsável por TI apresenta teste de recuperação do serviço de faturamento até a data acordada” cria um compromisso verificável, desde que escopo e recursos estejam definidos.

A frequência inicial quinzenal e os 30 minutos são parâmetros locais. Rever a cadência quando decisões pendentes ou indisponibilidade da direção tornam o ritual insuficiente. Adaptação é parte do método, não descumprimento de uma norma externa. **F09 F10**

Modelo: **Decisão e prioridades**. Próxima leitura: **Maturidade**.

15. Usar assistência por IA

IA pode ajudar a recuperar conteúdo, preparar uma minuta, classificar solicitações ou conferir requisitos. Seu uso é opcional. Uma equipe que mantém as mesmas práticas e evidências de forma manual pode alcançar qualquer nível de maturidade do GEAR.

Responsável por TI ou dono da tarefa seleciona o contexto; pessoa com autoridade adequada revisa decisões e aprova efeitos organizacionais. Entrada: dados autorizados, fontes, tarefa e critérios de saída. Saída: proposta revisada ou registro de insuficiência de dados.

Quatro funções de assistência

O modelo conceitual separa orquestração, análise de entrega, apoio a segurança e auditoria de indicadores. A implementação histórica contém um orquestrador e oito especialistas. Esses números descrevem níveis distintos: funções do método e componentes de software. Não são pilares adicionais nem prova de autonomia.

Preparar e revisar

1. Explicitar tarefa, dados disponíveis, restrições e formato de saída.
2. Separar fontes de instruções. Um documento recuperado pode conter texto incorreto ou instruções que não pertencem à tarefa.
3. Solicitar que lacunas apareçam como dado insuficiente, sem criar cifra, contato, configuração ou referência.
4. Executar cálculos com regras determinísticas e conferir as unidades.
5. Revisar alegações contra as fontes e distinguir proposta de ação executada.
6. Obter aprovação humana antes de priorizar, investir, mudar acesso, conter incidente ou publicar.

Elaborar uma melhoria por etapas

O mestre técnico de junho de 2026 propunha quatro etapas de elaboração: PRD, histórias e critérios, código inicial e roteiros de teste. Essa sequência pode ser usada com ou sem IA. Ao usar assistência, revisar a saída de cada etapa antes de fornecer contexto à seguinte; uma lacuna não se torna fato por ter sido repetida por outro agente.

1. Preparar problema, beneficiário, escopo e hipóteses no PRD.
2. Transformar o comportamento esperado em histórias e critérios verificáveis, com aceite pelo dono do processo.
3. Se houver desenvolvimento, preparar código em ambiente autorizado, conferir dependências e manter condição de retorno.
4. Definir e executar testes que verifiquem os critérios; registrar resultado, limites e aprovação.

O código preparado não comprova funcionamento. O roteiro não comprova que o teste ocorreu. Um teste técnico aprovado não comprova benefício financeiro. A pessoa responsável mantém essas distinções no registro da entrega. A sequência é proposta local preservada do manual técnico, não validação empírica de agentes encadeados.

Decidir sobre utilidade

Comparar esforço total de preparação, revisão e correção com a rotina manual. Registrar tipo de tarefa, amostra e período. Fluência da resposta, quantidade de texto e confiança declarada pelo sistema não medem correção ou ganho de produtividade.

HITL significa revisão humana com responsabilidade e critério; uma confirmação automática de toda saída não torna o processo controlado. A ausência de IA não é uma lacuna metodológica.

Modelos: **contratos de histórias, código, testes, relatório e exercício e revisão de saída assistida.**
Para a fundamentação e limites: **Origens e adaptações.**

16. Escolher e integrar ferramentas

Use quando a rotina precisar de suporte tecnológico ou a ferramenta atual limitar registro, proteção, recuperação ou entrega. TI verifica requisitos e operação; usuários testam o fluxo; finanças confere custos; direção decide contratação e risco. A escolha começa pela tarefa e sua evidência de conclusão.

Este guia é uma proposta local consolidada do apêndice de ferramentas de fevereiro de 2026. Os nomes de produtos abaixo preservam o catálogo histórico; não confirmam preços, planos, funcionalidades atuais ou adequação ao ambiente. Antes de escolher, conferir documentação oficial e termos da versão candidata, referenciando o trecho utilizado.

Definir o que a ferramenta precisa resolver

1. Registrar o problema, quem usa, volume, dados e condição de operação. Distinguir necessidade essencial de conveniência.
2. Verificar o que já existe. Um registro consultável pode atender a gestão; proteção de contas e recuperação exigem controles tecnológicos apropriados.
3. Definir critérios observáveis: tarefa concluída, permissões corretas, dados recuperáveis e acompanhamento possível. Informar dispositivo, carga, rede e recorte do teste.
4. Comparar poucas alternativas com a mesma base de custo e operação. Incluir implantação, treinamento, integração, manutenção, suporte, recorrência e saída.
5. Executar um piloto autorizado com dados adequados. Registrar erros, esforço de operação e limitações, incluindo indisponibilidade e exportação quando pertinentes.
6. Propor a decisão com evidências e pendências. Contratação, integração com dados reais e alteração de acesso têm alçada própria.

Comparação copiável

Critério	Necessidade local	Alternativa e evidência	Lacuna ou custo
Uso e acessibilidade	[tarefa, usuários, dispositivo]		
Dados e permissões	[dados autorizados, acesso, registro]		
Continuidade	[retenção, recuperação, dependências]		
Integração	[entrada, saída, formato, erro]		
Custo total	[horizonte e componentes]		
Operação e suporte	[responsável, atualização, atendimento]		
Crescimento	[volume e restrição observável]		
Saída	[exportação, substituição, encerramento]		

Um plano gratuito ou trial pode exigir tempo, infraestrutura e mudança futura de contrato. Código aberto também exige instalação, atualização e operação. A análise financeira usa **custos e hipóteses**, sem afirmar ROI por categoria ou marca.

Catálogo histórico por tarefa

Tarefa	Nomes citados no acervo	Conferência necessária
Quadro e portfólio	Trello, Asana, Miro, quadro físico	Estados, responsáveis, capacidade, histórico e acesso
Comunicação e registro	Slack, Microsoft Teams, WhatsApp Business	Captura consultável, permissões, retenção e escalonamento
Orientação recorrente	ManyChat, Dialogflow, bots nativos	Conteúdo mantido, resolução confirmada e encaminhamento humano
Planilha e painel	Google Sheets, Microsoft Excel, Looker Studio, Power BI	Origem, janela, permissões e atualização dos dados
Inventário	Planilhas, CMDB simplificada, Snipe-IT	Cobertura, proprietário, revisão e dependências
Cópia e transferência	Google Drive, OneDrive, Veeam Backup & Replication, rsync	Retenção, separação, proteção e restauração; sincronização não comprova backup
Verificação técnica autorizada	OpenVAS, Nmap Scripting Engine, OWASP ZAP	Escopo autorizado, impacto, aplicabilidade dos achados e revisão especializada
Código e colaboração	GitHub, GitLab, Bitbucket	Histórico, permissões, revisão e recuperação
Desenvolvimento	VS Code, PyCharm, GitHub Copilot, Codeium	Ambiente, dependências, autorização dos dados e revisão de código
Testes	Selenium, Playwright, Pytest	Critérios, ambiente, resultado e limites da cobertura
Assistência opcional	Gemini, ChatGPT, Claude, OpenAI API, Google AI Studio, Anthropic API	Dados autorizados, modelo, custo, erro e revisão humana
Privacidade e documentação	OneTrust, DataGrail, Confluence, Notion, Google Docs	Registros de tratamento, acesso, direitos, revisão e conservação

“Google Data Studio” era o nome usado em parte do catálogo; “Looker Studio” também aparecia entre parênteses. Os demais nomes são os declarados nos rascunhos, podendo ter mudado. O catálogo serve à recuperação documental, sem preferência comercial ou lista de requisitos do GEAR.

Integrar de modo verificável

Descrever sistema de origem, destino, dados, identidade, permissão, frequência e responsável. Definir o que acontece quando a operação falha ou é repetida: como detectar, registrar, corrigir e evitar duplicidade no recorte. Testar a exportação e a condição de retorno quando a integração puder comprometer dados ou serviço.

Automação precisa de código, ferramenta registrada, credenciais apropriadas e observação do resultado. Um prompt não implementa API, monitoramento, chatbot ou teste de restauração. A

geração de script é uma minuta de código a revisar; execução e efeito precisam de registros próprios.

Encerrar a escolha

Saída: decisão com requisito, alternativas, custo no período, evidência de teste, aprovador, responsável pela operação e pendências. Concluir a escolha quando o motivo puder ser conferido e houver condição de operação e revisão. Se nenhuma alternativa atender, registrar a limitação e renegociar necessidade, recorte ou capacidade.

Fundamentos de continuidade: NIST **F01**, **F02** e CISA **F12**. Esses documentos não endossam o catálogo histórico. Próximo registro: **carteira de iniciativas**.

17. Indicadores operacionais

Escolha um indicador quando houver uma decisão a tomar. TI coleta os dados; o dono do serviço confirma o que foi medido; direção e TI definem tolerâncias. Uma meta sem janela, origem e responsável não permite avaliar a rotina.

Definições

Indicador	Cálculo e unidade	Limite de interpretação
IDSC: disponibilidade de serviço crítico	$(\text{horas observadas} - \text{horas indisponíveis}) / \text{horas observadas} \times 100$, em %	Definir serviço, horário coberto e exclusões; não somar incidentes simultâneos duas vezes
TMpR: tempo médio para restauração	Soma dos tempos de recuperação / incidentes encerrados, em horas	Informar quantidade e distribuição; a média pode ocultar um incidente longo
ISU: satisfação do usuário	Soma das notas / respostas válidas, em escala 1 a 5	Informar taxa de resposta e pergunta; ausência de respostas é dado insuficiente
Trabalho iniciado	Quantidade por executor em andamento, teste ou bloqueio	Não confundir tamanho da fila com WIP
Tempo de fluxo	Conclusão menos início, na unidade escolhida	Informar política de pausa e itens ainda abertos

Coletar e revisar

1. Definir decisão e serviço: por exemplo, se a recuperação atende à necessidade do faturamento.
2. Escolher período e fonte. Preservar horários e identificador do incidente.
3. Validar domínios: horas observadas positivas, indisponibilidade entre zero e o período; duração não negativa; notas de 1 a 5.
4. Calcular e informar amostra, lacunas e exclusões.
5. Comparar com tolerância local e períodos comparáveis.
6. Registrar ação, responsável e data de revisão.

Sem incidentes encerrados, TMpR é **dado insuficiente**, não zero. Um período sem incidentes registrados pode indicar falta de coleta. Indicadores não substituem testes de restauração nem a avaliação de riscos.

Metas e compatibilidade

As versões anteriores usavam disponibilidade >99,5%, TMpR <4 horas e ISU >4,5. São exemplos de metas locais, sem validade universal. A calculadora mantém esses padrões para compatibilidade e permite configuração; o resultado deve declarar as metas aplicadas. Igualdade no limite não satisfaz uma comparação estrita.

DORA para entrega de software

As métricas DORA consultadas em 2026 são frequência de implantação, tempo de entrega de mudanças, tempo de recuperação de implantação com falha, taxa de falha de mudanças e taxa de retrabalho de implantação. Seu recorte é entrega de software. Não substituir TMpR de incidentes gerais pelo tempo de recuperação de uma implantação com falha. Consultar definições e contexto antes de incorporar uma métrica **F05**, **F06**.

Exemplo: 720 horas observadas e 2 horas de indisponibilidade produzem IDSC de 99,7222%. Dois incidentes restaurados em 1 e 3 horas produzem TMpR de 2 horas. Duas respostas 5 e 4 produzem ISU de 4,5; a amostra é pequena e não prova satisfação de todos.

Próxima leitura: **Indicadores financeiros**. Modelo: **Decisões e prioridades**.

Consulta complementar: **indicadores de negócio e comparação da rotina**, com definições para custos, canais, entregas e autoatendimento.

18. Indicadores de negócio e comparação da rotina

Este catálogo recupera indicadores dos guias anteriores para decisões que os três indicadores operacionais não respondem. Selecionar somente medidas com uso definido. Financeiro confere custos e receita; dono do processo confere escopo e benefício; TI mantém os registros. As definições abaixo são convenções locais do GEAR.

Conferir custos e canais

Medida	Cálculo no mesmo período	O que conferir
Custo de TI sobre receita	$\text{Custo total de TI} / \text{receita bruta} \times 100$, em %	Incluir pessoal, serviços, licenças e infraestrutura segundo a política financeira; declarar o tratamento dos investimentos
Participação dos canais digitais	$\text{Receita dos canais digitais} / \text{receita total} \times 100$, em %	Definir canais e atribuição de vendas; evitar contar a mesma venda em dois canais

Receita positiva é necessária para calcular as proporções. Um aumento da participação digital pode decorrer de redução de outros canais, sem crescimento da receita total. A medida não demonstra a contribuição causal da TI. Custos e receita precisam de base contábil e janela comparáveis; a antiga recomendação de 2-6% não tinha suporte para uso universal.

Conferir experiência digital

ISU é uma média de notas de 1 a 5, conforme os **indicadores operacionais**. Uma pesquisa com clientes pode usar média de notas ou uma proporção de respostas consideradas satisfeitas, desde que informe pergunta, escala, limiar, janela e quantidade de respostas.

Na convenção local de proporção, calcular respostas que atendem ao critério de satisfação / respostas válidas $\times 100$. Uma média de 4,5 em escala de 1 a 5 não é automaticamente 90% de pessoas satisfeitas. Sem respostas, registrar dado insuficiente. Informar taxa de resposta e o universo convidado quando conhecidos.

O guia antigo misturava média, CSAT percentual e NPS na mesma linha. São instrumentos distintos. Esta edição não converte nem estabelece equivalência entre eles; NPS e seus antigos limites não integram o cálculo do GEAR. A escolha de outro instrumento exige documentar sua definição e referência específica.

Conferir entregas e suporte

Tempo de lançamento

Medir data de disponibilização acordada – data de início do PRD, em dias corridos ou úteis declarados. Registrar aprovação, início de implementação e conclusão para distinguir espera e execução. Uma implantação técnica e a disponibilização ao usuário podem ter datas diferentes. Itens ainda abertos não entram como concluídos; mostrá-los separadamente para evitar ocultar atrasos.

Uma janela de uma ou duas semanas pode orientar um piloto pequeno. Não é meta universal de lançamento. O tempo de fluxo do quadro começa no início do trabalho; esse ponto pode diferir do início do PRD.

Entregas dentro de prazo e orçamento

Calcular entregas concluídas que cumpriram prazo e orçamento / entregas concluídas elegíveis $\times 100$. Usar os dois critérios em conjunto e indicar quantidades. Fixar a versão do prazo e orçamento; quando houver renegociação, conservar o acordo inicial e apresentar os resultados nas duas bases. Sem entregas elegíveis, o resultado é dado insuficiente. Cancelamentos e itens abertos devem aparecer no relatório, mesmo quando excluídos da proporção.

O indicador não mede sozinho a utilidade da entrega. Aceite e benefício observado exigem evidência própria. A antiga meta de 80% era parâmetro local sem validação externa.

Incidentes por colaborador

Calcular incidentes abertos no período / colaboradores do universo definido. Declarar se o denominador é média do período ou posição em uma data. Separar incidentes de pedidos de acesso, dúvidas e mudanças. Conferir duplicatas e mudanças de cobertura.

Mais registros podem indicar melhor captura. Uma queda pode indicar menos falhas ou dificuldade de pedir ajuda. Comparar serviços, exposição, população e política de classificação antes de interpretar tendência; redução contínua não é requisito de maturidade.

Registrar antes e depois

Definir a situação inicial pela coleta, sem preencher percentuais presumidos. Comparar períodos equivalentes e registrar outras mudanças que possam explicar o resultado. TI coleta; dono do serviço verifica; direção decide a ação. A comparação é descritiva, sem atribuir causalidade ao framework.

Tema	Registro em cada período	Evidência e limite
Captura de demandas	Demandas únicas observadas e quantas têm registro oficial	Reconciliar formulário, e-mail e contatos informais; denominador desconhecido impede percentual confiável
Restauração	Início, recuperação, serviço e incidentes encerrados	Usar TMpR para restauração; tempo até fechamento administrativo é outra medida

Tema	Registro em cada período	Evidência e limite
Autoatendimento	Solicitações elegíveis, resolução confirmada e regra de atribuição	Acesso à FAQ ou interação com bot não comprova resolução; registrar retorno ao suporte
Testes de recuperação	Escopos planejados, executados, aprovados e limitações	Um teste aprovado não garante outros serviços nem ausência de falha futura
Decisões com o negócio	Autoridade, motivo, recurso, prazo e acompanhamento	Ata assinada demonstra registro; verificar se a ação ocorreu e se a decisão foi revista
Maturidade	Resposta e evidência por pergunta, total e lacunas	Reaplicar a mesma edição; aumento do total não elimina um risco crítico

Concluir a revisão quando dados, exclusões, diferenças e ação estão registrados com responsável e prazo. Sem comparação suficiente, descrever o que passou a ser observável e planejar a coleta; não declarar redução de 30%, resolução de 40% ou cobertura de 90% por adoção do método.

Usar coleta assistida

Planilhas e scripts podem calcular medidas definidas. IA pode ajudar a classificar uma amostra autorizada, mas a pessoa responsável confere categorias, duplicatas e cálculos. Um painel atualizado não é previsão de anomalias validada. Se classificação ou acesso aos dados mudarem, declarar a quebra de comparabilidade.

Anterior: **Indicadores operacionais**. Próxima leitura: **Indicadores financeiros**. Para executar: **Conduzir uma revisão**.

19. Indicadores financeiros e hipóteses

Use estas convenções para discutir uma melhoria, seu custo e suas premissas. TI estima esforço e dependências; finanças confere valores; o dono do processo verifica o benefício; direção decide. Todos os valores devem estar na mesma moeda e base de preços, com período declarado.

Não confundir as medidas

Medida	Fórmula	Significado
Razão benefício/investimento	B / I	Quantas unidades de benefício bruto estimado correspondem a uma unidade investida
ROI líquido no período	$(B - C - I) / I \times 100$	Retorno após investimento e custos recorrentes do período
Payback simples	$I / (b - c)$	Meses para recuperar investimento, se benefício e custo mensais constantes e benefício líquido positivo
Economia potencial de capacidade	horas liberadas $\times$ custo por hora	Valor atribuído ao tempo; pode não reduzir despesa paga
DAN financeiro local	custo estimado de refatoração / orçamento anual de TI	Peso de uma estimativa de dívida sobre o orçamento; sem faixas universais
Proporção de itens legados	itens legados / itens totais	Composição do inventário; não mede custo de refatoração

I é investimento inicial positivo; B e C são benefício bruto e custo recorrente no período; b e c são seus valores mensais. Escrever “400% de ROI” para $B/I \times 100$ confunde razão bruta e retorno líquido.

Exemplo calculado

Investimento de R\$ 9.000; benefício bruto estimado de R\$ 3.000/mês; custo recorrente de R\$ 500/mês; horizonte de 12 meses. Benefício bruto anual: R\$ 36.000. Custo recorrente anual: R\$ 6.000. Razão benefício/investimento: 4. ROI líquido anual: $(36.000 - 6.000 - 9.000) / 9.000 \times 100 = 233,33\%$. Payback simples: $9.000 / 2.500 = 3,6$ meses.

Sem custo recorrente, o mesmo cenário tem ROI líquido de 300% e razão bruta de 4, equivalente a 400% do investimento. São resultados condicionais de uma conta, não retorno observado do GEAR.

COT e tempo liberado

COT significa **Custo de Otimização Tecnológica** nesta edição. Registrar o investimento inicial, seus componentes e os custos de operação separadamente. Não usar COT como sinônimo de custo de oportunidade ou como fórmula de ROI.

Se uma automação libera 20 horas por mês a R\$ 50/hora, há R\$ 1.000/mês de capacidade potencial. Para tratá-la como redução de despesa, demonstrar uma alteração efetiva de gasto ou contratação.

Se as horas forem realocadas, medir a nova entrega, sem contar simultaneamente capacidade e receita derivada como benefícios independentes.

Sensibilidade e decisão

Apresentar cenários conservador, central e favorável variando adoção, benefício, manutenção e investimento. Se o benefício líquido mensal for zero ou negativo, não há payback simples finito. A fórmula não contempla inflação, tributos, risco, valor do dinheiro no tempo ou fluxos irregulares; investimentos que dependem desses fatores exigem análise financeira apropriada.

DAN financeiro exige estimativa explicada: sistema, escopo de correção, método, data e incerteza. Uma proporção de 30% de itens legados não demonstra DAN financeiro de 0,30 nem risco de falência. A API antiga mantém faixas abaixo de 0,15, de 0,15 a 0,35 e acima de 0,35 apenas como critérios locais da proporção de inventário, explicitamente rotulados. Outras versões usavam limites diferentes; nenhum deles foi validado como limiar financeiro.

Saída: memória de cálculo, fonte das premissas, responsável e decisão. Evidência de conclusão: finanças e dono do processo conferiram unidades e hipóteses. Estas fórmulas são convenções locais; não há atribuição ao NIST, COBIT ou ITIL.

Os guias antigos também atribuíam a DAN ao ATDx e o ROI do COT à dívida de arquitetura empresarial. ATDx normaliza violações por elementos de código e usa análise estatística; Hacks et al. propõem uma definição contextual com casos fictícios. Esses textos apoiam conceitos de dívida arquitetural, mas não as fórmulas financeiras ou faixas do GEAR. **F13 F14**

Anterior: **Indicadores operacionais**. Aplicação: **Caso didático**.

20. Comparar uma tarefa com e sem assistência

Use quando houver uma decisão sobre continuar, ajustar ou suspender o uso de IA. A pessoa responsável pela tarefa define o recorte; quem aceita a entrega confere qualidade; direção decide investimento. A equipe pode atingir qualquer nível de maturidade sem adotar IA.

Preparar uma comparação útil

Escolher tarefas comparáveis, registrar dificuldade, experiência do executor, ferramenta, versão, dados permitidos e critério de aceite. Medir todo o esforço: preparação, geração, leitura, conferência, correção e teste. Cronometrar somente a geração omite trabalho necessário.

Medida local	Cálculo ou registro	Limite de interpretação
Tempo por entrega aceita	Esforço total até o aceite	Comparar tarefas com escopo e qualidade equivalentes
Variação relativa de tempo	$(\text{tempo de referência} - \text{tempo assistido}) / \text{tempo de referência} \times 100$	Referência positiva; valor negativo indica aumento de esforço
Aceitação sem revisão relevante	Entregas aceitas sem correção relevante / entregas avaliadas $\times 100$	Definir “relevante”; aceite não prova ausência de erro
Erros por entrega	Erros identificados / entregas verificadas	Manter o mesmo método e profundidade de verificação
Custo por entrega aceita	Custos atribuíveis / entregas aceitas	Incluir ferramenta, revisão, correção e infraestrutura
Capacidade recuperada	Horas de referência – horas assistidas	Tempo potencial, sem equivalência automática a economia financeira

Os nomes históricos TGA, TMRIA, TAA, CAG e TEIA descreviam tempo, aceitação, custo ou variação. A edição vigente exige unidade e evento de início/fim explícitos. Resposta inicial, restauração de serviço e fechamento administrativo são medidas distintas. Não atribuir causalidade à IA se o processo, a equipe ou o tipo de demanda também mudou.

Decidir com os resultados

1. Conferir amostra, exclusões, falhas e tarefas não concluídas.
2. Comparar esforço e qualidade, conservando os registros individuais.
3. Examinar se a vantagem depende de dados, pessoa, fornecedor ou contexto específicos.
4. Registrar continuar, ajustar, ampliar o teste ou suspender; indicar dono e próxima verificação.

Concluir quando a decisão pode ser reconstruída a partir das entradas e das entregas verificadas. Sem baseline, registrar apenas a medição atual. Sem denominador ou observações comparáveis, não preencher percentual. A antiga meta de redução de 60% não é requisito do GEAR.

Fundamento: instrumento local de avaliação, derivado dos indicadores candidatos do acervo. Estudos sobre assistência têm tarefas e populações próprios; seus resultados não predizem o ganho desta equipe. Consulte a bibliografia do manuscrito e os **limites de atribuição das fontes**.

Consulta: **comparação da rotina** e **revisão de saída assistida**.

21. Uma adoção ilustrativa

Este caso é fictício e serve para exercitar os registros. Não é estudo de campo, depoimento ou resultado médio esperado. A empresa do exemplo tem 25 pessoas, um responsável por TI e suporte terceirizado; depende de um sistema de pedidos para faturar.

Situação inicial

Pedidos de acesso chegam por mensagem, falhas são resolvidas sem horário registrado e há backup com status de sucesso, mas sem teste recente. Direção e TI escolhem acompanhar o processo de faturamento. O dono do processo confirma impacto; TI organiza as dependências e o fornecedor confirma suas responsabilidades.

Uma decisão de prioridade

Há três demandas: corrigir acesso indevido, testar recuperação e automatizar um relatório. A primeira requer contenção conforme impacto; o teste verifica uma dependência crítica; a automação pode aguardar capacidade. A matriz de impacto e urgência ajuda a discutir; esforço e dependências são registrados separadamente. Risco e obrigação impedem uma ordenação puramente aritmética.

TI registra aprovador, executor e aceite. Duas tarefas em execução e uma em teste já ocupam o limite inicial de três. Uma quarta melhoria permanece na fila. Quando surge incidente crítico, a autoridade registra a exceção e qual trabalho foi suspenso, mantendo seu histórico e o bloqueio visíveis.

Recuperação e aprendizado

O teste autorizado restaura uma cópia de dados em ambiente separado. A verificação encontra uma dependência de licença que impede iniciar o serviço. A conclusão correta é “dados restaurados; serviço ainda não recuperado”. O fornecedor assume a correção e outro teste é marcado. Não há declaração de continuidade comprovada.

Hipótese financeira

O relatório consome 20 horas/mês estimadas por observação. Atribuir R\$ 50/hora produz R\$ 1.000/mês de capacidade potencial. Investimento de R\$ 3.000 e manutenção de R\$ 100/mês, se as 20 horas forem liberadas integralmente, dão benefício bruto anual de R\$ 12.000, custo recorrente de R\$ 1.200, ROI líquido estimado de 260% e payback simples de 3,33 meses.

Se apenas metade das horas for liberada, benefício de R\$ 500/mês: ROI líquido estimado de 60% e payback de 7,5 meses. Se as horas liberadas não reduzirem despesa, os valores representam capacidade, e não economia realizada. O benefício precisa de medição posterior e não pode ser lançado como receita da empresa.

Revisão

Ao fim da janela, a equipe compara registros e evidências por pergunta de maturidade. Pode ter melhorado a visibilidade da fila sem concluir a recuperação. Registra esse resultado parcial, responsáveis e próxima decisão. O aprendizado útil é localizar a lacuna e tratá-la, sem forçar uma narrativa de sucesso.

Práticas: **Priorizar**, **Testar restauração**, **Entregar melhoria**. Convenções: **Financeiros**.

22. Cenários fictícios do acervo

O apêndice C de fevereiro de 2026 descrevia TechSolutions, DataGuard e InovaTech como estudos de caso, com percentuais de resultado. O documento não apresentou registros de coleta, participantes, instrumentos ou dados que comprovassem observação real. Esta edição os conserva como cenários fictícios para discussão. Nomes, dimensões e números pertencem ao exercício, sem vínculo confirmado com empresas reais.

TechSolutions: fila e decisão

Perfil do exercício: desenvolvimento de software, quinze funcionários e faturamento anual de R\$ 2 milhões. Situação descrita: projetos frequentes, prazos perdidos e comunicação insuficiente com clientes. O nível inicial 0 foi uma atribuição do rascunho; não há dez respostas e evidências para confirmá-lo.

Práticas a discutir: registro oficial, quadro, orientação dos usuários, pauta de direção e definição de indicadores. A resistência inicial pode ser investigada ouvindo usuários e testando o fluxo; não presumir que treinamento ou demonstração resolvam a adoção.

O texto antigo declarava redução de 40% no tempo de resposta e aumento de 20% na satisfação. São números imaginados sem baseline, período, amostra ou definição de medida. Não calcular resultado real, nem confundir resposta inicial com restauração. Aumento de satisfação precisa explicitar se é relativo, em pontos ou outra unidade.

Perspectiva SWOT do exercício	Questão para a decisão
Força: abertura a tecnologia e apoio à redação	O fluxo atende à tarefa e foi verificado pelos usuários?
Fraqueza: processos pouco definidos e dependência de uma pessoa	Quem substitui o responsável e onde ficam os registros?
Oportunidade: ampliar práticas e testes	Qual lacuna justifica a próxima ação dentro da capacidade?
Ameaça: perda de conhecimento e competição	Que continuidade e documentação precisam de prioridade?

DataGuard: acesso e recuperação

Perfil do exercício: consultoria de segurança, oito funcionários e faturamento anual de R\$ 1,5 milhão. Situação descrita: plano de incidentes ausente, cópias não testadas e dificuldade de acompanhar vulnerabilidades. O nível inicial 1 também era presumido.

Práticas a discutir: inventário por serviço, acesso, teste autorizado de recuperação, contatos e alçadas do PRI, exercício de mesa e dados pessoais. Scripts ou classificação assistida são propostas a revisar, não controles já executados.

O rascunho declarava redução de 90% no tempo de resposta, “100% de conformidade” de backup e melhoria de conformidade à LGPD. Nenhuma dessas conclusões tem evidência no documento. A recuperação precisa de recorte, tolerância e resultado; conformidade legal não decorre da presença de planilha ou política.

Perspectiva SWOT do exercício	Questão para a decisão
Força: conhecimento de segurança	A capacidade sobre configuração, resposta e revisão necessárias?
Fraqueza: equipe pequena e monitoramento limitado	Que cobertura existe e qual exposição permanece aceita?
Oportunidade: oferecer serviços e preparar análise de logs	Quais contratos, acessos e verificações são necessários?
Ameaça: mudança de ameaças e regras	Quem acompanha as fontes pertinentes e revisa o plano?

InovaTech: requisitos e entrega

Perfil do exercício: startup de tecnologia, vinte desenvolvedores e faturamento anual de R\$ 5 milhões. Situação descrita: ciclo de desenvolvimento lento, dificuldade de preparar MVPs e retrabalho de requisitos. O nível inicial 2 não foi medido no texto.

Práticas a discutir: PRD, histórias, critérios, código, testes e piloto com revisão entre etapas; biblioteca de instruções quando houver uso de assistência. A adesão da equipe precisa de observação, não de conclusão presumida após workshop.

O texto antigo declarava redução de 50% no ciclo PRD/código, aumento de 30% na produtividade e três MVPs em seis meses. Esses dados são fictícios. Definir início/fim do ciclo, esforço de revisão e correção, amostra, custo e qualidade antes de comparar; quantidade de entregas não demonstra utilidade.

Perspectiva SWOT do exercício	Questão para a decisão
Força: experiência técnica e disposição para experimentar	Quais critérios permitem avaliar o piloto?
Fraqueza: dependência de IA e manutenção das instruções	Qual saída exige revisão e quem mantém a biblioteca?
Oportunidade: novas entregas e atração de pessoas	Qual benefício é hipótese e como será observado?
Ameaça: custo de modelos e concorrência	Quais alternativas e sensibilidades mudam a decisão?

Variações do documento acadêmico completo

O mestre acadêmico continha uma segunda TechSolutions Ltda.: quinze pessoas, cinco em desenvolvimento, duas em suporte e oito em comercial/marketing. Essa composição não é a mesma do cenário de vinte pessoas chamado TechSolutions PME no rascunho de simulação. Conservar perfis separados ao usar os exercícios.

A variação de quinze pessoas supunha quadro digital, e-mail, formulário e dez FAQs. Declarava, após trinta dias, redução de 45% no tempo de resposta, 95% de requisições registradas e 60% de FAQs resolvidas. São valores fictícios sem coleta verificável. Para testar a hipótese, conferir captura de demandas, resolução confirmada e esforço de manutenção da base.

Metalúrgica Alfa S.A.: cenário fictício de manufatura com oitenta pessoas, um gerente de TI e dois analistas de suporte. O exercício propunha reunião mensal de 45 minutos com direção e produção,

priorização e painel de custo/receita, disponibilidade e prazo de projetos. Declarava aumento de 15% no ROI e redução de 20% no custo de TI/receita em seis meses. Sem custos, benefícios, receitas, baseline ou definição de variação, esses números não permitem calcular nem comprovar resultado. A questão preservada é como produção e TI decidem recursos e verificam dependências.

PixelBoost Agência Digital: cenário fictício com vinte e cinco pessoas, incluindo três desenvolvedores, um designer e dois gerentes de projeto. O exercício propunha requisitos, histórias, código, testes, ciclos semanais e retrospectiva. Declarava redução de 60% no ciclo PRD/código e aumento de 30% na capacidade em três meses. São hipóteses numéricas, sem dados ou equivalência de qualidade. Medir preparação, revisão e correção antes de discutir ganho; cada etapa exige conferência, inclusive histórias e testes.

TechSolutions PME: minimundo fictício de vinte pessoas e um responsável por TI, com dependência de vendas e CRM e intenção de expandir. O rascunho sugeria agentes para representar direção, finanças, TI e clientes. Esse desenho não comprova que o simulador tenha sido executado ou reproduza comportamento humano. Separar entradas, regras e resultados simulados de evidência organizacional.

Aplicar o exercício sem fabricar resultado

Escolher um cenário e preparar perfil, diagnóstico por evidência, práticas, obstáculos, resultados ou hipóteses, decisões e SWOT. A SWOT é uma lente local de discussão, não uma medição causal. Registrar dono, lacuna e próxima ação para os pontos relevantes.

Os cinco temas preservados do apêndice são adoção gradual, assistência sob revisão, comunicação, indicadores úteis e revisão da rotina. Verificar no contexto se há resistência, excesso de registro, confiança indevida na saída ou ausência de alçada. Um questionário não precisa preceder resposta a incidente ou necessidade urgente.

Para documentar uma aplicação real, indicar origem, autorização de uso dos dados, período, método de coleta, instrumentos, amostra, mudanças concorrentes e limitações. O protocolo acadêmico do projeto continua prospectivo; os exercícios acima não preenchem seus resultados.

Modelos: **comparar antes e depois, maturidade, PRD e aceite, risco e continuidade.**

23. Templates de trabalho

Para assistência opcional: **prompts de direção, entrega, segurança e indicadores**, usados com o registro de revisão humana.

Use o modelo que resolve a necessidade atual. Campos vazios indicam informação a obter, não aprovação implícita. Cada registro precisa de responsável, data e evidência; guardar histórico quando a decisão mudar.

Necessidade	Modelo	Quem verifica
Definir alçadas e papéis acumulados	Responsabilidades	Direção e pessoas designadas
Ordenar fila e registrar escolha	Decisões e prioridades	Autoridade de aprovação
Discutir impacto e urgência	Matriz de prioridades	TI e dono do processo
Delimitar uma melhoria	PRD e aceite	Dono do processo
Preparar resposta	Incidente	Responsável por continuidade
Registrar exposição e recuperação	Risco e continuidade	Proprietário do risco
Rever uma saída assistida	Revisão de IA	Responsável humano pela saída
Avaliar a rotina	Maturidade	TI e dono do processo
Rever medidas e ações	Painel de indicadores	TI e dono do serviço
Conhecer ativos e dependências	Inventário	Proprietário do serviço
Atribuir passos e verificar resultado	Lista de tarefas	Executor e dono do processo
Preparar uma delegação ou pedido	Instrução de tarefa	Responsável pela tarefa
Elaborar histórias, código, testes, relatório ou exercício	Contratos por etapa	Revisor técnico e pessoa com alçada
Revisar PRD, testes, plano, logs ou processo	Revisão operacional	Responsável pela tarefa e autoridade pertinente
Comparar serviços e iniciativas em conjunto	Carteira de iniciativas	Direção, finanças e donos dos processos
Conhecer tratamento de dados pessoais	Dados e privacidade	Competência responsável por privacidade

Os modelos são instrumentos do GEAR, não formulários normativos de suas referências. Pode-se acrescentar um campo necessário e retirar um campo sem uso, preservando a rastreabilidade da prática.

24. Registro de responsabilidades

Preencher no início da adoção e revisar após mudanças de pessoas ou fornecedores. Direção confirma alçadas; cada pessoa confirma disponibilidade e acesso. Saída: lista consultável de responsáveis e substitutos.

Processo/serviço: [preencher] **Data e responsável pelo registro:** [preencher]

Função	Pessoa ou fornecedor	Decide o quê	Limite da alçada	Substituto/contato
Patrocinador/direção		Recursos e risco aceito		
Responsável por TI		Organização e execução		
Dono do processo		Necessidade e aceite		
Executor		Trabalho autorizado		
Segurança/continuidade		Teste e resposta		

Acúmulos e conflitos: [quem acumula aprovação e execução; como haverá segunda conferência quando necessária].

Comunicação: [registro oficial, contato de urgência, frequência de atualização e destinatários].

Verificação: pessoas designadas confirmaram os papéis em [data/evidência]. Exceções: [ausência de substituto, serviço terceirizado, limites de disponibilidade]. Não preencher nomes fictícios no registro operacional.

RACI-Lite por atividade

Quando houver dúvida entre funções, usar R para executor, A para autoridade de aprovação, C para pessoa consultada e I para pessoa informada. Identificar uma autoridade final por decisão; se houver mais de uma aprovação necessária, explicitar decisões e alçadas distintas.

Atividade	R: executor	A: autoridade	C: consultado	I: informado
Orçamento anual de TI				
Priorização da fila				
Triagem e atendimento				
Teste de recuperação				
Requisitos e aceite da melhoria				

Uma ferramenta pode preparar a minuta ou auxiliar o teste. Registrar a pessoa responsável pela execução e conferência; não atribuir à IA a alçada humana. Validar disponibilidade e conflitos antes de considerar a tabela vigente. A quantidade de linhas é ajustável ao serviço.

25. Decisão e prioridade

Use para uma demanda, investimento ou revisão de fila. TI prepara fatos; dono do processo explica impacto; autoridade de aprovação decide. Este registro pode ser um cartão do quadro.

- Identificador, data e solicitante: [preencher]
- Problema e processo afetado: [situação observada]
- Evidências e fontes: [link, período e limitações]
- Opções consideradas: [inclusive adiar ou não executar]
- Impacto, urgência, esforço e dependências: [estimativa e incerteza]
- Riscos e proprietário: [preencher]
- Capacidade e trabalho já iniciado do executor: [preencher]
- Decisão e motivo: [preencher]
- Aprovador e limite de alçada: [preencher]
- Executor, prazo e critério de conclusão: [preencher]
- Data de revisão e comunicação ao solicitante: [preencher]

A matriz de quatro finalidades relaciona a demanda a receita, custos, experiência e resiliência. Registrar finalidade principal e efeitos secundários. Impacto e esforço ajudam a decidir a ordem; não alteram o significado dessa matriz nem dispensam risco, urgência ou dependência. Uma obrigação urgente pode anteceder uma melhoria de alto impacto.

Concluir quando a decisão estiver atribuída e comunicada. Se faltar dado essencial, registrar a investigação e seu responsável. Se a prioridade mudar, acrescentar nova decisão, preservando a anterior.

26. Matriz de impacto e urgência

Use para discutir demandas concorrentes. Dono do processo explica impacto; TI verifica dependências e esforço; autoridade de aprovação decide. Esta matriz é distinta das quatro finalidades: receita, custos, experiência e resiliência.

	Urgência menor	Urgência maior
Impacto maior	Agendar com capacidade, dependências e prazo	Avaliar prioridade e exceções necessárias
Impacto menor	Questionar necessidade, adiar ou delegar	Conferir impacto e prazo; executar conforme capacidade

Urgência alta não demonstra que a demanda é rápida ou fácil. Um bug de faturamento pode ter impacto alto; classificar pelo efeito observado. Fronteiras alto/baixo são locais e devem ter exemplos acordados.

Demanda	Impacto e evidência	Prazo e motivo de urgência	Esforço/dependência	Decisão e responsável
---------	---------------------	----------------------------	---------------------	-----------------------

[preencher]

Saída: ordem acordada, itens adiados e motivo. Concluir quando solicitantes conhecerem a decisão e cada item selecionado tiver executor e aceite. Risco, obrigação, emergência ou dependência podem alterar a ordem; registrar no [modelo de decisão](#).

Origem: template histórico References/GP-PME Versions/matriz_4_quadrantes.md, revisto para retirar associação automática entre urgência e facilidade. Instrumento local, sem validade universal atribuída a fonte externa.

27. PRD curto e registro de aceite

Use para uma melhoria delimitada. Dono do processo valida a necessidade; TI confere viabilidade; executor verifica o comportamento; usuário ou dono do processo aceita a saída.

Definição

- Identificador, versão, responsável e data: [preencher]
- Problema observado e evidência: [preencher]
- Usuário/processo beneficiado: [preencher]
- Resultado esperado e hipótese de benefício: [preencher]
- Escopo incluído: [preencher]
- Exclusões: [preencher]
- Restrições, permissões e dependências: [preencher]
- Risco, proprietário e mitigação: [preencher]
- Recursos e prazo estimados: [preencher]

Verificação

Critério observável	Como testar	Quem verifica	Resultado/evidência
[Dado... quando... então...]			

Plano de retorno: [como desfazer ou mitigar falha; responsável].

Aceite: [pessoa, data, critérios atendidos e pendências].

Acompanhamento do benefício: [indicador, linha de base, janela, fonte e decisão futura]. Aceite funcional não comprova benefício financeiro. Se o recorte não couber na capacidade, renegociar escopo ou prazo antes de iniciar.

Histórias e requisitos operacionais

História: Como [perfil real], quero [comportamento] para [finalidade]. Usar quantas forem necessárias ao recorte, sem inventar persona, fluxo ou regra de negócio para atingir duas ou três histórias. Requisito desconhecido permanece como pergunta com responsável.

Requisito	Condição e limite acordados	Ambiente e modo de verificar	Responsável
Desempenho	[ação, quantidade de dados e tempo]	[dispositivo, rede, carga e amostra]	
Acesso/segurança	[perfis, permissões e exceções]	[teste autorizado de permitido/negado]	

Requisito	Condição e limite acordados	Ambiente e modo de verificar	Responsável
Usabilidade	[tarefa, usuários e dispositivos]	[verificação com usuário e limitações]	

Uma meta de dois segundos precisa dessas condições. Erro de formulário deve ser identificável e permitir correção; não usar apenas cor para descrevê-lo. Excluir uma funcionalidade exige acordo e consequência declarados, sem retirar um requisito necessário para que o recorte seja utilizável.

Exemplos fictícios para iniciar uma conversa

- Financeiro: baixar extratos de três bancos e digitar valores em uma planilha consome tempo e pode gerar erro. O relato antigo de três horas por dia é hipótese do exemplo; conferir frequência, acesso, formatos e custo antes de calcular benefício.
- Comercial: leads de um formulário demoram a receber resposta. A proposta de encaminhá-los ao vendedor exige regras de atribuição, permissão, horário e teste de entrega; o relato de dois dias e venda perdida não é medição do projeto.
- Suporte: pedidos por mensagens ficam dispersos. Definir captura e acompanhamento, preservando acesso à ajuda; não supor que metade das tarefas foi perdida.

Outros exemplos dos modelos anteriores incluíam iniciar atendimento de um lead, informar campo obrigatório ausente e acompanhar pedido. São comportamentos a discutir, sem obrigação de integrar WhatsApp, coletar CPF ou criar aplicativo. Nenhuma história comprova benefício antes da avaliação.

Conferir o preenchimento

TI e negócio descrevem o problema, acordam critérios antes de implementar, delimitam escopo e identificam quem aprova. Uma conversa de quinze ou vinte minutos pode preparar a minuta; ampliar quando houver lacunas. Uma ou duas páginas são preferência de síntese, com evidências e detalhes vinculados. Um piloto de duas semanas depende de capacidade e escopo, sem garantia universal.

Assistência opcional: **contrato de requisitos e entrega**. A IA pode preparar propostas; dono do processo aprova regras e aceite, e TI confere viabilidade. Não preencher solicitante, data ou orçamento desconhecidos por inferência.

28. Plano breve de resposta a incidente

Preparar antes de uma ocorrência. Durante o incidente, usar o registro para coordenar ações e preservar evidências. Segurança ou TI mantém o plano; direção confirma alçadas; dono do serviço define tolerância de interrupção.

- Serviço e dados afetados: [preencher]
- Responsável e substituto: [preencher]
- Contatos conferidos em: [data; TI, fornecedor, direção, jurídico quando aplicável]
- Como reconhecer e classificar: [impacto e critério local]
- Quem pode isolar, suspender acesso e autorizar recuperação: [preencher]
- Onde registrar horários, decisões e evidências: [preencher]
- Comunicação: [destinatários, canal, frequência, aprovador]
- Recuperação: [cópia, dependências, ambiente, teste de integridade e aceite]
- Obrigações a avaliar: [competência responsável; não improvisar requisito legal]

Durante e depois

1. Registrar descoberta, impacto conhecido e incertezas.
2. Acionar responsáveis; conter conforme autorização e preservar evidências.
3. Atualizar negócio com fatos verificados e próxima atualização.
4. Recuperar em condição segura e conferir serviço com seu dono.
5. Registrar encerramento, limitações e correções atribuídas.

Exercício: [cenário, data, participantes, resultado e próxima revisão]. Não considerar o plano testado só por ter sido assinado. Não colocar credenciais no documento.

Fundamento: orientação CISA **F12**, adaptada a um registro breve do GEAR.

29. Risco e continuidade

Use quando uma dependência pode impedir o serviço ou expor informações. Proprietário do serviço descreve impacto; TI verifica controles e recuperação; direção aceita risco dentro da alçada.

Campo	Registro
Serviço, proprietário e data	
Ativos, dados e fornecedores críticos	
Evento e consequência	
Evidência de exposição e incerteza	
Controles existentes e verificação	
Tratamento escolhido, responsável e prazo	
Risco residual e aprovador	
Tempo de recuperação tolerável (RTO)	
Perda de dados tolerável (RPO)	
Backup, proteção, retenção e responsável	
Teste: cenário, ambiente, horários e resultado	
Validação do serviço pelo negócio	
Pendências e próxima revisão	

O teste pode recuperar um arquivo, uma base ou o serviço inteiro. Declarar o recorte para que a conclusão corresponda à evidência. Se o tempo medido exceder a tolerância, registrar o desvio e decidir tratamento, sem alterar o objetivo retroativamente para declarar sucesso.

Fundamento: NIST **F01**, **F02** e CISA **F12**. O formato é uma adaptação local.

Análise qualitativa e assistência opcional

Se usar probabilidade e impacto baixo/médio/alto, definir critérios, origem e incerteza antes de combinar categorias. Sem evidência, registrar hipótese a investigar, sem converter rótulo em probabilidade numérica. A análise local não certifica conformidade NIST ou CIS.

Tarefa: preparar minuta de análise de risco do GEAR.

Entrada: [serviço, ativo, uso, dependências e evidências autorizadas].

Saída: evento, exposição verificada ou hipótese, consequência, controles existentes, lacunas, alternativas, esforço, responsável e verificação.

Quando houver classificação qualitativa, usar os critérios informados.

Não inferir vulnerabilidade, CVE, configuração ou probabilidade por marca.

Não garantir custo zero, proteção integral ou recuperação em prazo fixo.

Conferir fontes externas junto à afirmação, incluindo versão e trecho.

Identificar autoridade para contenção, comunicação e aceitação de risco.

Deixar contato não fornecido pendente; não prescrever isolamento universal.

A pessoa responsável confere a análise e autoriza os efeitos apropriados.

Cenários fictícios dos modelos anteriores

- ERP em nuvem com dados cadastrais e financeiros. O exemplo mencionava cinco mil clientes e acesso por senha; é hipótese didática. Conferir identidade, MFA, dados tratados, permissões e recuperação antes de avaliar exposição.
- Serviço de arquivos de escritório contábil com versão antiga de Windows Server e acesso compartilhado. Confirmar versão, suporte, permissões e cópia; “antigo” não identifica sozinho uma vulnerabilidade ou CVE.
- Notebooks usados em viagens com propostas e planilhas confidenciais. Conferir acesso, criptografia, atualização, guarda e recuperação; não inferir configuração real pelo cargo do usuário.

Na análise manual, partir do efeito sobre o serviço, conferir acesso e evidências de cópia e recuperação, depois comparar tratamentos. Frequência mensal ou trimestral depende do requisito local. Uma falha de controle precisa de investigação e resposta proporcional, não de ordem automática de alteração sem alçada.

Verificações complementares locais

As skills anteriores mantinham dez verificações de segurança. Esta lista conserva a cobertura do modelo, como seleção autoral a adaptar. Ela não representa o catálogo completo do NIST CSF ou do CIS IG1, nem demonstra conformidade por quantidade de itens marcados.

Verificação	Evidência a obter no recorte
Hardware e dispositivos	Inventário, proprietário, uso, localização e cobertura desconhecida
Software e serviços	Versões, uso autorizado, responsável e dependências
Vulnerabilidades	Origem da informação, aplicabilidade, correção ou exceção e verificação
Configuração	Baseline local, funções necessárias, alterações e revisão

Verificação	Evidência a obter no recorte
Contas e autenticação	Contas individuais, cobertura de MFA, exceções e recuperação de acesso
Privilegio	Permissões necessárias, contas administrativas e revisão
Proteção contra malware	Cobertura, atualização, alertas e resposta no ambiente
Cópias e recuperação	Retenção, separação, proteção e teste com resultado e limites
Rede	Fluxos necessários, regras e conferência de filtragem no recorte
Orientação de pessoas	Situações abordadas, participação, modo de verificar e atualização

Para cada item, registrar implementado no recorte verificado, em andamento, ausente ou não verificado, com fonte, data, responsável e próxima ação. O resumo informa cobertura conhecida; não converter evidência de um equipamento em cobertura de toda a empresa.

As três perguntas manuais de identidade, privilégio e recuperação ajudam a iniciar a análise. Elas complementam a lista, sem substituí-la. A ordem dos controles e a frequência de revisão dependem da exposição e do serviço; a antiga escolha de quatro itens por menor esforço não demonstrava redução de risco medida.

Grade qualitativa opcional

Esta grade preserva a combinação usada nas skills anteriores. Seus rótulos são convenções locais; definir primeiro o significado dos eixos, sua evidência e incerteza. A ausência de dado sobre probabilidade permanece não verificada, sem escolher “baixa” por padrão.

Probabilidade local / impacto local	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico
Média	Baixo	Médio	Alto
Baixa	Baixo	Baixo	Médio

A classificação orienta conversa e tratamento; não estima frequência de ataque, não autoriza alteração automática e não substitui a análise de consequência e alçada. Registrar o risco residual e o motivo da decisão.

Modelo complementar: **inventário de dependências**. Para resposta operacional: **incidente**.

30. Revisão de uma saída assistida por IA

Aplicar antes de usar uma saída de IA em decisão, comunicação ou mudança. O responsável humano pela tarefa verifica conteúdo e autorização. Não enviar dado restrito a uma ferramenta sem permissão e controles adequados.

- Tarefa, data, responsável e ferramenta/modelo quando conhecido: [preencher]
- Informações fornecidas e classificação: [preencher sem reproduzir segredo]
- Saída pretendida e autoridade para usá-la: [preencher]
- Fatos conferidos e fontes consultadas: [preencher]
- Citações verificadas no documento original: [preencher]
- Cálculos, unidades e premissas conferidos: [preencher]
- Dados pessoais ou confidenciais removidos/protegidos: [preencher]
- Limitações, erro observado e correção: [preencher]
- Aprovação, rejeição ou necessidade de investigação: [pessoa e motivo]
- Evidência da versão usada e próxima revisão: [preencher]

Uma resposta fluente não é evidência. Se não for possível verificar uma afirmação material, retirá-la, restringi-la ou identificá-la como hipótese. A assinatura do revisor não substitui acesso à fonte.

Conclusão: somente a saída revisada e autorizada segue para uso. A equipe pode executar a mesma tarefa sem IA.

Conferências por tipo de saída

Aplicar os blocos pertinentes ao efeito proposto, registrando motivo quando um item não se aplica. Uma conferência feita por outro modelo pode ajudar a localizar divergências, mas não substitui o revisor humano nem comprova ausência de erro.

Rastreabilidade

- [] Fatos correspondem aos dados fornecidos ou a fontes conferidas?
- [] Sistemas, interfaces e configurações reais estão separados das propostas?
- [] Lacunas, estimativas e incertezas estão explícitas?
- [] Referências indicam versão e trecho que sustenta a afirmação?
- [] Cálculos usam moeda, unidades, período e premissas compatíveis?

Uma alternativa de ferramenta pode ser proposta com justificativa, custo e verificação pendentes; ela não passa a ser uma aquisição real. Não exigir marcas já compradas para toda análise nem considerar qualquer sugestão uma configuração existente.

Requisitos

- ☐ História descreve usuário, comportamento e finalidade verificáveis?
- ☐ Critério informa condição, ação e resultado observável?
- ☐ Escopo e exclusões foram acordados com o negócio?
- ☐ Dependências e capacidade tornam o recorte viável ou têm lacunas atribuídas?

Segurança e continuidade

- ☐ Acesso proposto é necessário ao efeito e suas exceções foram revistas?
- ☐ Controles têm cobertura e evidência, sem promessa de proteção integral?
- ☐ Recuperação e contenção consideram ambiente, autoridade e preservação de evidências?
- ☐ Recursos e manutenção foram considerados, inclusive para soluções nativas?

Código e configuração

- ☐ Dependências, APIs, comandos e valores foram conferidos na versão aplicável?
- ☐ Entrada, acesso e erros relevantes foram testados em ambiente autorizado?
- ☐ Segredos e detalhes internos não aparecem indevidamente na saída?
- ☐ Regras de negócio implementadas têm revisão e critérios acordados?
- ☐ Placeholder, demonstração e integração real estão identificados?
- ☐ Plano de retorno e aprovação para a mudança estão registrados?

Código inicial pode conter lacunas explícitas; não é apto ao uso operacional apenas por ser executável. Também não há proibição universal de gerar lógica completa: seu uso exige revisão, testes e autorização apropriados.

Registrar o resultado

Item/afirmação	Evidência consultada ou teste	Resultado e limitação	Correção necessária	Responsável
----------------	-------------------------------	-----------------------	---------------------	-------------

[preencher]

Decisão: [aprovado para o uso delimitado / ajustar / rejeitar / investigar], com pessoa, data, motivo, versão e pendências. Aprovação editorial não autoriza automaticamente implantação. Erro material exige correção ou restrição do uso; registrar divergência sem prometer “zero alucinações”. Duração de cinco minutos e revisão de três fatos não são critérios de qualidade.

31. Registro de maturidade

Preencher com TI e dono do processo usando o **questionário**. Comparar apenas aplicações com contexto e janela conhecidos.

Organização/processo: [preencher] **Data, janela de evidência e avaliadores:** [preencher]

Pergunta	Resposta 0/1	Evidência, data e limite	Ação quando insuficiente
1. Registro e responsável			
2. Capacidade e fluxo			
3. Orientações verificadas			
4. Prioridades decididas			
5. Escopo e aceite			
6. Dependências críticas			
7. Recuperação testada			
8. Acesso controlado			
9. Indicadores rastreáveis			
10. Revisão responsável			

IM-TI e nível descritivo: [soma e faixa]. **Mudanças em relação à aplicação anterior:** [prática, evidência e contexto]. **Até três ações prioritárias:** [responsável e prazo]. **Lacunas críticas e risco aceito:** [aprovação e motivo]. **Próxima revisão:** [data e responsável].

Concluir com evidências consultáveis e pendências atribuídas. Este registro não constitui certificação nem exige IA.

32. Painel de indicadores e decisões

Use na revisão da rotina quando houver uma decisão apoiada por medidas. TI prepara dados; dono do serviço confere o escopo; direção e TI acordam tolerâncias e ações. Um painel pode ser preenchido em planilha ou papel; não exige coleta automática.

Identificação e cálculo

- Serviço/processo e responsável: [preencher]
- Período, horário observado e exclusões: [preencher]
- Origem dos dados, versão do cálculo e data da coleta: [preencher]

Indicador	Dados de entrada e quantidade	Resultado/unidade	Tolerância local e comparação	Limite da interpretação
IDSC	Horas observadas e indisponíveis	[%]		
TMpR	Duração de restauração e incidentes encerrados	[horas; quantidade]		
ISU	Notas 1-5 e respostas válidas	[média; quantidade]		
Outro indicador escolhido	[definição, período e fonte]			

Sem denominador válido, registrar dado insuficiente. Não usar queda da média como sinal automático de melhoria; comparar escopo, quantidade e casos longos. As metas históricas >99,5%, <4 horas e >4,5 são exemplos locais configuráveis, sem validade universal.

Decisão e acompanhamento

Questão a decidir	Evidência e alternativas	Decisão/motivo	Autoridade	Executor e prazo	Próxima verificação
[preencher]					

Concluir quando a pessoa responsável conferiu dados e unidades e a decisão ou necessidade de coleta está atribuída. Cálculo assistido por IA exige a mesma conferência; não preencher um resultado por suposição.

Definições: **operacionais** e **negócio/comparação**. Próximo modelo: **decisões e prioridades**.

33. Inventário de ativos e dependências

Use para compreender o que sustenta um serviço e preparar sua proteção e recuperação. Dono do serviço define impacto; TI verifica dependências; proprietário confirma responsabilidade. Começar pelos serviços críticos e registrar cobertura parcial. Criticidade não se deduz do cargo de quem usa o equipamento.

Serviço e cobertura

- Serviço/processo, proprietário e data de revisão: [preencher]
- Consequência da indisponibilidade e evidência: [preencher]
- RTO e RPO acordados, com justificativa: [preencher]
- Escopo inventariado, lacunas e responsável pela ampliação: [preencher]

ID e ativo/dependência	Tipo e localização	Proprietário e fornecedor	Criticidade/motivo	Dados e acesso necessários
[preencher]				

ID	MFA/acesso: evidência e exceção	Cópia: frequência e retenção	Recuperação: teste e limite	Ação, responsável e prazo
[vincular ao ativo]				

Registrar referência à evidência com acesso adequado; não guardar senhas ou chaves neste modelo. “MFA ativo” exige configuração verificada e escopo declarado. “Backup ativo” exige identificar solução, fonte e retenção; teste de arquivo não comprova recuperação de todo o serviço.

Se for usada criticidade de 1 a 5, definir cada faixa e exemplos com o dono do processo. A escala é local e não mede porcentagem de risco. Dependências de um ativo crítico podem precisar de tratamento mesmo quando seu uso parece secundário.

Conferir e atualizar

TI compara registro e ambiente; proprietário confirma uso e impacto. Registrar alteração após mudança de conta, integração, fornecedor ou serviço. Concluir o recorte quando ativos conhecidos estão atribuídos e lacunas têm plano; não declarar inventário completo enquanto faltar cobertura.

O nome anterior “Inventário 80/20” expressava priorização, sem prova de que 20% dos ativos representam 80% da receita ou risco. Exemplos antigos de ERP, planilha financeira, notebook e serviço de chamados são possibilidades de ativo, não configuração real do projeto.

Fundamento: **segurança e continuidade**, NIST F01–F02. Próximo modelo: **risco e continuidade**.

34. Lista de tarefas e verificação

Use para uma mudança ou rotina que precise de passos atribuídos. TI organiza dependências e capacidade; executor registra resultado; dono do processo aceita o efeito pertinente. A lista complementa o quadro, sem criar uma segunda fila divergente.

Preparar o recorte

- Iniciativa/rotina, período e responsável geral: [preencher]
- PRD ou decisão que autoriza, escopo e exclusões: [preencher]
- Permissões, dependências, ambiente e condição de retorno: [preencher]

ID e ação	Executor	Dependência	Estado	Critério e modo de verificar	Resultado/evidência
[preencher]			[A Fazer/Em Andamento/Em Teste/Concluído]		

Bloqueio ou suspensão: [item, motivo, início, responsável pela próxima ação e revisão]. Manter o relógio e o histórico de trabalho iniciado. Contar andamento, teste e bloqueio comprometido no WIP por executor; marcar início de tarefa não cria capacidade adicional.

Opções de organização

Agrupar por preparação e ambiente; desenvolvimento ou configuração; verificação técnica e de negócio; disponibilização e acompanhamento. Essas são opções do modelo antigo, sem impor quatro fases ou quatorze dias a toda atividade. Segurança e requisitos podem precisar de conferência antes da execução, não apenas ao final.

- Preparação: verificar acesso e dependências em ambiente autorizado.
- Implementação: executar o recorte acordado e guardar alterações.
- Verificação: testar critérios, acesso, falhas relevantes e retorno conforme o efeito.
- Disponibilização: confirmar autorização, comunicação, operação e acompanhamento.

Exemplos fictícios de critérios: membros autorizados acessam um repositório e demais não; um formulário informa um campo obrigatório ausente; mensagem de teste chega ao destino autorizado. Definir ambiente, amostra e prazo necessários; a antiga referência a dez segundos não é padrão de pagamentos ou e-mail. Mensagem de console não comprova recebimento externo.

Encerrar e revisar

Registrar teste realizado, pessoa que verificou, aceite ou motivo de encerramento. Uma assinatura registra aprovação, sem substituir teste. Nem toda tarefa exige publicação ou implantação. Guardar pendências e condição de revisão posterior do benefício.

As marcações antigas [], [/] e [x] podem ser mantidas como legenda em ferramentas que as suportem. Elas não representam sozinhas teste, bloqueio ou aceite; conservar esses campos explicitamente. Não apresentar [/] como checkbox Markdown padrão.

Saída: lista atualizada vinculada ao quadro. Concluir quando resultados e pendências são localizáveis, com responsável. Referência de uso: **entregar melhoria**. Próximo modelo: **PRD e aceite**.

35. Instrução de tarefa e assistência

Use para delegar uma tarefa a uma pessoa ou preparar um pedido de assistência por IA. O responsável fornece contexto autorizado e define quem revisa. O formato conserva o antigo Formulário de Alinhamento de Instrução (FAI), sem presumir que uma persona ou lista impede erro.

Modelo copiável

Tarefa e papel necessário: [ação delimitada e especialização pertinente].
Contexto: [serviço, processo, problema observado e pessoas afetadas].
Dados autorizados: [origem, data, unidade, período e limitações].
Restrições: [capacidade, orçamento conhecido, permissões e dependências].
Entradas: [documentos e dados fornecidos, separados das instruções].
Etapas: [ações necessárias e pontos de conferência].
Saída: [formato, seções, extensão adequada e critérios verificáveis].
Autoridade: [quem revisa e quem pode aprovar efeitos].
Lacunas: registrar dado insuficiente e o que obter; não preencher por suposição.
Estimativas: informar fonte, unidade, período, método e incerteza.
Fontes externas: conferir versão e trecho; citar junto à afirmação.
Fatos, hipóteses e propostas permanecem identificados.
Comandos, configurações e mudanças só são executados com autorização adequada.

Para uma pessoa, combinar papel, dados, etapas, saída e alçada antes de iniciar. Para IA, limitar acesso aos dados necessários e conferir a saída. Nenhuma forma elimina o trabalho de revisão. Dados históricos de mercado só entram como premissa quando sua fonte e pertinência foram verificadas; não suprem custo real da organização.

Exemplo fictício: preparar migração de e-mail

O exemplo anterior mencionava Advocacia Lima, dez usuários, provedor IMAP, histórico de dois anos e licenças Microsoft 365 Business Basic. Esses dados são um cenário didático, sem evidência de organização real, aquisição ou viabilidade de migração.

Tarefa: preparar uma proposta de migração de e-mail para avaliação humana.
Contexto fictício: escritório jurídico com dez usuários e histórico de dois anos em provedor IMAP; licenças Microsoft 365 Business Basic informadas.
Janela desejada: sexta-feira às 19h; gestão DNS informada no Registro.br.
Saída: etapas de preparação, preservação e conferência das mensagens, opções de janela, condição de retorno e testes de envio/recebimento.
Campos a conferir: domínio, caixas, volume, autenticação, ferramentas de migração suportadas, registros DNS, retenção e dependências do fornecedor.
Indicar a fonte oficial e versão para qualquer procedimento específico.
Deixar valores DNS pendentes até conferência; não inventar servidores.
Não garantir tempo de propagação nem ausência de interrupção.
O responsável por TI confere viabilidade; autoridade aprova a mudança.

O exemplo é um pedido de planejamento, não roteiro técnico verificado de Microsoft 365 ou Registro.br. A menção antiga a PST, TXT, MX, SPF, DKIM e TTL passa a ser lista de aspectos a investigar conforme o ambiente e documentação oficial; nenhum valor ou prazo é prescrito aqui.

Concluir a preparação quando tarefa, dados, saída, lacunas e revisão estão claros. Aplicação: **usar IA**. Contratos específicos: **quatro funções**.

36. Prompts para quatro funções de assistência

Use quando a equipe escolhe assistência por IA para uma tarefa delimitada. Estes textos preservam as quatro funções do capítulo técnico anterior; não descrevem a quantidade de especialistas de software nem autorizam execução. Quem prepara informa contexto e dados autorizados; quem tem alçada revisa a saída. Uma equipe pode executar a mesma tarefa sem IA.

Direção e prioridades

Tarefa: preparar uma pauta ou minuta de decisão do GEAR.

Contexto: [processo, demandas, capacidade, decisões anteriores e riscos].

Dados autorizados: [origem, janela, unidades e limitações].

Autoridade de decisão: [pessoa e alçada].

Saída: problema, alternativas, finalidade de negócio, recurso necessário, risco, responsável, prazo, evidência esperada e próxima revisão.

Relacionar a iniciativa a receita, custos, experiência ou resiliência, declarando hipótese de benefício e efeitos secundários quando houver.

Usar português direto, títulos informativos e registro breve consultável.

Informar dados insuficientes e decisões pendentes. Conferir cálculos com regra determinística; indicar fontes externas no ponto da afirmação.

A pessoa responsável revisa a pauta; a autoridade identificada decide.

Requisitos e entrega

Tarefa: preparar PRD e critérios verificáveis para uma melhoria do GEAR.

Contexto: [problema observado, usuário e processo beneficiado].

Dados autorizados: [fontes e evidências disponíveis].

Restrições: [permissões, dependências, recurso, capacidade e prazo].

Saída: problema, hipótese, escopo, exclusões, histórias de usuário, critérios Dado/Quando/Então, riscos, teste, retorno e aceite esperado.

Uma ou duas semanas podem orientar um piloto se o escopo couber na capacidade informada. Se faltar informação, registrar a pergunta e seu responsável. Estimativas devem ter origem, unidade e incerteza.

Conferir cada etapa antes de preparar a seguinte. Código inicial e roteiro de teste são propostas; registrar separadamente execução e resultado.

Dono do processo aprova requisitos e aceite; TI confere viabilidade.

Segurança e continuidade

Tarefa: preparar análise de lacunas ou plano breve de resposta do GEAR.

Contexto: [serviço, ativos, dependências, risco observado e controles].

Dados autorizados: [relato, configuração, evidência e limites de acesso].

Autoridade: [quem decide contenção, comunicação e recuperação].

Saída: fatos, hipóteses, dados insuficientes, opções de tratamento, responsável, contatos a conferir, verificação e risco residual.

Priorizar conforme criticidade do serviço, sem usar 80/20 como medida de risco. Comparar alternativas por cobertura, esforço e manutenção.

Conferir CVEs e fontes primárias antes de citar uma vulnerabilidade.

Propor contenção apropriada ao ambiente, preservando evidências. A pessoa com alçada autoriza a ação; o executor verifica recuperação com o negócio.

Dez verificações locais não equivalem ao NIST CSF ou CIS IG1 completos.

Indicadores e revisão

Tarefa: conferir premissas, unidades, cálculos e referências do GEAR.

Entrada: [documento, dados, período, moeda, origem e limitações].

DAN financeiro local = custo estimado de refatoração / orçamento anual TI.

Indicar método, escopo e incerteza; não atribuir faixas universais de risco.

ROI líquido no período = (benefício bruto - recorrência - investimento)

/ investimento * 100. Razão bruta = benefício bruto / investimento.

Payback simples mensal = investimento / benefício líquido mensal positivo,

somente se fluxos forem constantes. Sem benefício positivo, não é finito.

Horas liberadas são capacidade potencial salvo redução de despesa comprovada.

Manter precisão no cálculo e declarar arredondamento na apresentação.

Conferir a afirmação na fonte citada e distinguir proposta, simulação e resultado observado. Se faltar moeda, custo ou período, registrar a lacuna; informar horas isoladamente não permite afirmar ROI financeiro.

Saída: memória de cálculo, divergências, incerteza e revisão humana necessária.

Conferir o uso

Aplicar o **registro de revisão**. Um texto aprovado deve permitir localizar fatos, premissas, fontes e pessoa responsável. A adesão do prompt a um formato não comprova correção da saída.

Origem: quatro system prompts em GP-PME antigravity/GP-Pme

complete/Capitulo_6_Motor_de_IA_e_Engenharia_de_Prompts.md. As instruções foram revistas para retirar garantia de proteção, faixas financeiras sem suporte e prazo obrigatório de MVP. São contratos locais de assistência. Convenções: **financeiros**; contexto: **usar IA**.

37. Contratos para etapas de elaboração

Use quando uma tarefa precisar de histórias, código inicial, testes, relatório ou exercício de resposta. Os cinco contratos preservam a biblioteca estendida de fevereiro de 2026. São instruções locais, sem garantia de acerto, redução de tempo ou execução. IA permanece opcional.

Fornecer o recorte autorizado, dados e fontes pertinentes. Conferir a saída antes de encadear outra etapa; informação ausente permanece pendente. Tamanho P/M/G, quantidade de critérios e extensão do relatório dependem do contexto. A pessoa responsável decide uso, implantação, comunicação ou publicação.

Histórias e critérios

Tarefa: transformar o PRD fornecido em histórias e critérios verificáveis.

Entrada: [PRD, regras conhecidas, perfis, contexto e fontes autorizadas].

Saída: Como [perfil], quero [ação], para [finalidade]; critérios pertinentes em Dado/Quando/Então, dependências e lacunas por história.

Preservar problema, escopo e exclusões acordados. Distinguir requisito fornecido, hipótese e proposta; não inventar tela, regra ou integração.

Se pedido, propor tamanho P/M/G com fatores e incerteza para a capacidade informada. Tamanho relativo não é estimativa comprovada de prazo.

Critérios descrevem condição, ação, resultado e modo de verificar.

Segurança, erro e recuperação entram quando pertinentes ao efeito.

Entregar minuta e pendências para revisão técnica e do dono do processo.

Código inicial delimitado

Tarefa: preparar estrutura inicial para a história e critérios fornecidos.

Entrada: [história, ambiente, linguagem, framework, versões e restrições].

Saída: proposta de arquivos, interfaces e código no recorte solicitado, com dependências, configuração necessária, lacunas e modo de verificar.

Python/Flask é uma opção do exemplo histórico, não tecnologia obrigatória.

Se esse ambiente for confirmado, preparar rota, método HTTP, validação pertinente e placeholder explícito da lógica ainda não implementada.

Separar exemplo de uso e resultado executado. Segredo fica em configuração apropriada, nunca incorporado ao exemplo. Conferir entrada, acesso e erro.

Não declarar endpoint funcional, integração real ou implantação por gerar código. Registrar ferramenta executada e resultado somente quando ocorrer.

Pessoa responsável revisa dependências, código, testes e autorização.

Testes por comportamento

Tarefa: preparar testes pertinentes para código e critérios fornecidos.

Entrada: [código, história, critérios, ambiente e dependências].

Saída: testes ou roteiro para sucesso, falha e fronteiras materiais, indicando qual critério cada caso verifica e que efeito fica fora do recorte.

Python/Pytest é opção histórica; confirmar linguagem e executor disponíveis.

Evitar teste que só repita o código sem verificar comportamento necessário.

Distinguir falha da implementação, falha do ambiente e requisito ambíguo.

Marcar roteiro ou código preparado como não executado até haver resultado.

Informar comando, ambiente, resultado e limite quando a execução ocorrer.

Aprovação técnica não comprova benefício financeiro ou aceite do negócio.

Relatório para revisão de direção

Tarefa: preparar relatório executivo com os registros fornecidos.

Entrada: [indicadores com origem/período, carteira, decisões, riscos e metas].

Saída: situação, evidências, prioridades, riscos, alternativas, decisão necessária e pendências com responsável. Usar linguagem direta.

Escolher indicadores pela decisão: disponibilidade/restauração/satisfação ou custo TI/receita/prazo e orçamento, conforme dados e definições conhecidas.

Não chamar esses dois conjuntos de trio único obrigatório do framework.

Conferir numerador, denominador, janela, amostra e memória de cálculo.

Usar metas acordadas; falta de dado não vira resultado ou causa presumida.

Uma página pode orientar síntese, sem omitir informação material.

Identificar minuta e pessoa com alçada; aprovação e reunião não são simuladas.

Exercício de mesa de resposta

Tarefa: preparar cenário fictício de exercício de mesa de incidente.

Entrada: [serviço/ativo, ameaça escolhida, dependências, PRI e participantes].

Saída: objetivo, limites, descrição fictícia, linha do tempo de eventos, perguntas por etapa, decisões/alçadas, comunicação e registro de correções.

Exemplos históricos: e-commerce, serviço de arquivos, ransomware ou phishing com acesso indevido. A escolha não confirma ocorrência ou vulnerabilidade.

Indicar os dados necessários para avaliar contenção e recuperação; não prescrever desligamento, isolamento ou formatação para qualquer ambiente.

O exercício discute decisões. Alterar sistemas, executar varredura ou enviar comunicação real exige escopo e autorização próprios.

Registrar participantes, decisões observadas, lacunas, responsáveis e revisão.

Um exercício não comprova eficácia de resposta em qualquer incidente.

Exemplo fictício: acompanhamento de pedido

O prompt histórico descrevia e-commerce com estados “Processando”, “Enviado”, “Em trânsito” e “Entregue”, atualização a partir da logística, aviso por e-mail e link de acompanhamento. Conservar essas necessidades como cenário; regras de acesso e integração precisam de definição. “Tempo real” precisa de tolerância e modo de medir.

- História de consulta: cliente autorizado visualiza o estado fornecido pela logística. Conferir pedido próprio, estado conhecido, falha de atualização e apresentação no dispositivo combinado.
- História de aviso: mudança válida de estado gera aviso conforme regra acordada. Conferir destinatário autorizado, conteúdo, repetição e comportamento de falha. Opção de deixar de receber depende da regra aplicável, sem presumir equivalência entre aviso transacional e marketing.
- História de acesso: link leva ao acompanhamento com autorização apropriada. O exemplo antigo admitia pedido público sem login; a revisão deixa acesso e exposição para decisão explícita, sem publicar dados por padrão.

O PRD do exemplo sugeria reduzir chamadas em 20% e elevar satisfação em 10%. São alvos fictícios sem definição de baseline ou unidade; não são resultados nem metas do GEAR. Preparar coleta e forma de comparação antes de avaliar efeito. Logística, suporte, TI e cliente eram os perfis do exercício, sem presumir responsáveis de uma empresa real.

Rever e manter a biblioteca

Registrar tarefa, versão, responsável, ambiente/modelo quando usado, fontes, exemplos, comportamento esperado e resultado da verificação. Rever após mudança material de fonte, processo, permissões ou ferramenta. Manter alternativa manual e histórico, sem tornar a biblioteca condição de maturidade.

Fornecer exemplos e dividir etapas são opções de preparação; autorrevisão por modelo continua assistência. A justificativa deve apresentar fonte, cálculo e limite verificáveis. Solicitar raciocínio interno extenso não substitui evidência. Fine-tuning ou troca de modelo, citados no acervo, exigem avaliação própria; não se afirma que eliminem erros ou que prompt seja sempre mais importante que o modelo.

Saída: minuta por etapa e revisão registrada. Concluir quando a tarefa tem limites, critérios, fontes disponíveis e pendências, com decisão de uso atribuída. Modelos relacionados: **instrução de assistência, quatro funções e revisão de saída.**

38. Instruções para revisar requisitos e rotina

Contratos locais recuperados da biblioteca acadêmica anterior. Usar dados autorizados e revisar a saída antes de agir. Campo sem dado permanece pendente. Nenhuma instrução exige uso de IA no método.

Refinar um PRD

Tarefa: revisar o PRD fornecido, sem adicionar escopo aprovado.

Entradas: PRD, objetivo, usuários, restrições, dependências e critério de aceite.

Saída: trecho ambíguo; consequência; proposta de redação; pergunta pendente; requisito afetado; fonte da informação. Separar sugestão de requisito aprovado.

Conferir escopo, exclusões, autorização de acesso, requisitos não funcionais, testabilidade e medidas com unidade, período, responsável e origem.

Não presumir prazo ou benefício. Dono do processo aprova requisitos; TI confere viabilidade.

Preparar cenários de teste

Tarefa: propor testes para a história e os critérios fornecidos.

Entradas: história aprovada, critérios, perfis de acesso, regras, ambiente e restrições.

Saída por teste: requisito; contexto; ação; resultado esperado; dados; caso positivo, negativo ou limite; forma de observar; responsável.

Apontar critério não testável e pedir a decisão necessária. Não inventar comportamento.

Não afirmar que testes foram executados. Pessoa responsável confere cobertura e ambiente.

Preparar um plano de resposta

Tarefa: preparar minuta de PRL para o serviço e cenário informados.

Entradas: serviço, dependências, sintomas, controles, cópias, contatos, alçadas, tolerâncias de recuperação e perda de dados, comunicação e apoio externo.

Saída: reconhecer e registrar; acionar contatos; opções de contenção e seus riscos; preservar evidências; recuperar em ambiente autorizado; verificar serviço e dados; comunicar fatos confirmados; atribuir pendências e revisão.

Não inventar telefones, comprometimento, prazo legal ou alçada. Não prescrever desligamento, formatação ou isolamento como ação universal. Plano depende de aprovação da autoridade, conferência dos contatos e exercício. Incidente real segue a competência e o plano aprovados, sem aguardar esta minuta.

Examinar registros de operação

Tarefa: examinar os registros autorizados fornecidos.

Entradas: logs, período, fuso, serviço, evento investigado e limites de coleta.

Saída: ocorrência com referência ao registro; padrão observado; explicações possíveis; dados faltantes; verificação proposta; responsável e alçada.

Separar observação de hipótese. Não inferir causa ou ataque de correlação isolada.

Não fabricar CVE. Não executar correção nem divulgar registros sensíveis.

Propor uma melhoria de processo

Tarefa: rever o processo descrito e preparar opções de melhoria.

Entradas: etapas reais, responsáveis, tempos, bloqueios, demanda, capacidade, restrições, registros disponíveis e objetivo de negócio.

Saída: problema observado; opção; alternativa; custo/esforço; risco; hipótese de benefício; piloto; aceite; medida; dono; decisão necessária.

Não prometer redução de tempo nem atribuir procedimento local ao ITIL integral.

Quantidade de opções e cadência são ajustáveis. Autoridade decide; executor testa; dono do processo aceita e revê o benefício no período acordado.

Conferir e conservar

Concluir quando entradas, lacunas, proposta e responsável pela revisão estão visíveis. Na biblioteca, registrar versão da instrução, ferramenta/modelo, exemplo fictício, resultado conferido e data de revisão. Uma justificativa produzida pela ferramenta não substitui evidência externa ou teste técnico.

Consulta: **assistência opcional**, **PRD e aceite**, **incidente** e **fontes**. Os contratos são propostas do GEAR, sem validação causal atribuída à literatura.

39. Rever a carteira de iniciativas e serviços

Use quando projetos, serviços e custos precisarem ser comparados em conjunto. TI prepara registros; donos dos processos verificam uso e efeito; finanças confere custos; direção decide continuidade e recurso. Não é necessário esperar um nível de maturidade específico.

O módulo histórico de escalabilidade propunha revisão trimestral ou semestral. Essas são opções locais; escolher a janela conforme mudança, dependência e decisão necessária. Uma urgência pode exigir revisão anterior.

Preparar a carteira

- Período, versão, responsável pela preparação e autoridade: [preencher]
- Objetivos de negócio e capacidade disponível: [preencher]
- Dados consultados e limitações de cobertura: [preencher]

Iniciativa ou serviço	Dono e finalidade	Situação e evidência	Dependências e risco	Custo no período	Decisão necessária
[preencher]					

Incluir operação, manutenção e compromissos existentes; uma carteira limitada a projetos novos pode esconder custo e dependência. Registrar benefício como hipótese ou resultado com evidência, evitando somar duas vezes capacidade liberada e sua entrega decorrente.

Rever e decidir

1. Conferir quais itens atendem necessidade atual e quem usa seu resultado.
2. Identificar sobreposição, dependência e capacidade disputada. Dois sistemas parecidos podem ter requisitos distintos; a semelhança não autoriza encerramento.
3. Comparar continuar, ajustar, experimentar, adiar ou encerrar. Explicitar custo de transição, conservação de dados, alternativa de serviço e condição de retorno.
4. Conferir as hipóteses financeiras e suas sensibilidades. Retorno estimado favorável não elimina requisito de acesso, continuidade ou privacidade.
5. Registrar decisão, motivo, aprovador, executor, prazo e revisão. Se faltarem dados, atribuir a coleta e decidir o que pode seguir com segurança no recorte.

Registro da decisão

Campo	Registro
Item e alternativas consideradas	
Evidência, hipótese e lacunas	
Decisão e motivo	
Recurso e capacidade comprometidos	
Risco aceito e autoridade	
Transição, retorno e dados a conservar	
Executor, prazo e próxima conferência	

Mudança de arquitetura

O acervo associava crescimento a arquitetura evolutiva. Preservar a necessidade de conhecer dependências e custo de mudança; escolher arquitetura pela situação demonstrada. Um sistema monolítico não exige substituição automática por serviços distribuídos. Registrar o problema observável, opções, alteração mínima útil, riscos, teste e condição de retorno.

Saída: carteira com decisões localizáveis e pendências atribuídas. Concluir a revisão quando uso, custo, dependências e próximo passo estiverem explícitos para os itens discutidos. A revisão não comprova que todo investimento foi otimizado.

O formato é proposta local. A referência pública do COBIT apoia adaptação ao contexto **F09**; não se afirma ter implantado integralmente APO05 ou validado esta tabela. Consulta: **indicadores financeiros** e **responsabilidades**.

40. Registrar dados pessoais e responsabilidades

Use quando um processo tratar dados pessoais ou uma mudança alterar sua coleta, acesso, compartilhamento ou conservação. Dono do processo descreve a finalidade; TI identifica sistemas e controles; a competência responsável por privacidade confere obrigações e alçadas. Direção decide recursos e riscos dentro de suas responsabilidades.

Este registro é uma adaptação local do tema de privacidade do módulo histórico de escalabilidade. Não demonstra conformidade nem substitui análise jurídica. O NIST Privacy Framework aparecia como referência no rascunho; seus detalhes não foram adotados sem consulta específica.

Conhecer o tratamento

Campo	Registro
	Processo, responsável, data e versão
	Finalidade e pessoas cujos dados são tratados
	Categorias de dados e origem
	Hipótese legal e responsável por sua conferência
	Sistemas, fornecedores e compartilhamentos
	Quem decide o tratamento e quem o executa
	Acessos, controles e evidência de revisão
	Conservação, necessidade e condição de eliminação
	Atendimento de requisições do titular
	Exposições, consequências e pendências
	Resposta a incidente e competência responsável
	Próxima revisão e decisões registradas

O princípio da necessidade limita o tratamento ao mínimo necessário para sua finalidade, e o art. 7º prevê hipóteses legais além do consentimento. Portanto, obter consentimento não é uma solução universal para todo tratamento. Conferir a hipótese aplicável e requisitos específicos no contexto, inclusive quando houver dados sensíveis. **F15**, arts. 6º e 7º.

O art. 37 trata do registro de operações do controlador e operador. Esta tabela ajuda a organizar informação; campos preenchidos não comprovam suficiência do registro legal ou execução dos controles. **F15**, art. 37.

Conferir a mudança

1. Identificar quais dados a tarefa realmente precisa e quais campos podem ser removidos.
2. Confirmar finalidade, responsabilidade e hipótese legal com a competência indicada.
3. Conferir acesso, compartilhamento, conservação, proteção e recuperação nas dependências conhecidas.
4. Preparar fluxo para requisições dos titulares, com pessoa responsável, canal e registro. O art. 18 reúne direitos e condições; uma instrução curta não substitui sua leitura aplicável. **F15**
5. Registrar teste dos controles pertinentes e pendências. A LGPD prevê medidas técnicas e administrativas de segurança desde a concepção até a execução do produto ou serviço. **F15**, art. 46 e § 2º.
6. Submeter a decisão às pessoas com alçada e manter histórico após alteração relevante.

Quando ocorrer um incidente

Acionar o plano e avaliar consequência para titulares, responsabilidade do controlador e obrigação de comunicação. O art. 48 trata de incidente que possa acarretar risco ou dano relevante aos titulares. A orientação da ANPD consultada informa prazo geral de três dias úteis, ressalvado prazo de legislação específica; regras de contagem, marco inicial e exceções exigem conferência do ato aplicável. “PME” do framework não comprova enquadramento jurídico especial. **F15**, art. 48; **F16**, perguntas 4-6.

IA pode preparar uma minuta com dados autorizados e minimizados. Não enviar dados pessoais ou segredos por conveniência, nem considerar classificação textual ou política gerada como prova de conformidade. A decisão sobre o uso das informações precisa de autoridade e condição de acesso.

Saída: registro revisado, controles verificados no recorte e pendências atribuídas. Concluir a preparação quando finalidade, dependências, responsabilidade e próxima ação estiverem localizáveis; a avaliação legal continua sob a competência apropriada. Modelos relacionados: **inventário** e **incidente**.

41. Origens, adaptações e evolução

GEAR reúne práticas do acervo GP-PME e NEXUS-PME em uma edição coerente. A mudança de nome foi uma decisão editorial: Gestão, Execução, Agilidade e Risco descrevem as atividades do método sem criar um quarto domínio. O acervo contém versões com diferentes recortes; sua data não determina, por si, a qualidade ou completude.

Referência, adaptação e proposta local

Referência	Conceito consultado	Adaptação do GEAR e limite
NIST CSF 2.0 F01 , F02	Governar, Identificar, Proteger, Detectar, Responder e Recuperar	Priorização por serviço crítico e registro breve; seleção não cobre todo o CSF
Scrum Guide 2020 F03	Inspeção, adaptação, transparência e responsabilidade	Ciclos curtos e aceite; omitir elementos significa não implementar Scrum integralmente
TOGAF F04	Estrutura de conteúdo fundamental e guias de configuração	ADM-Lite é proposta local; não se afirma execução do ADM ou equivalência de fases
COBIT F09	Governança ajustada ao contexto	Alçadas e revisão breve; não representa todo o sistema COBIT
ITIL 4 F10	Gestão de serviços adaptável	Registro, recuperação e melhoria; não é implantação integral do ITIL
CIS F11 e CISA F12	Higiene cibernética e recuperação	Controles priorizados com evidência; quatro práticas não equivalem às 56 salvaguardas IG1
Diátaxis F08	Aprender, executar, consultar e compreender	Percursos de documentação; organização editorial, não método de gestão

WIP de três, revisão de 30 minutos, percurso de 30 dias, IM-TI, DAN financeiro e templates são escolhas locais. Não atribuir esses parâmetros às referências acima. Prazos e metas devem ser ajustados com motivo registrado.

O que foi consolidado

Versões anteriores chamavam IA de quarto pilar e adoção de quinto pilar. O modelo vigente mantém três domínios; IA é assistência opcional, e adoção, indicadores e maturidade são transversais. Os quatro papéis conceituais de IA descrevem funções; o software implementado tem um orquestrador e oito especialistas. Essas contagens pertencem a camadas diferentes.

Foram preservados mecanismos relacionais: conversa com o negócio, revisão de prioridades, comunicação de impedimentos, dono do processo, papéis acumulados e aprovação segundo alçada. Uma equipe pequena pode concentrar funções; precisa tornar visíveis os conflitos e buscar segunda conferência quando a decisão exigir.

“Fase Zero” de adoção foi separada da verificação pré-projeto. Razão benefício/investimento foi separada de ROI líquido; proporção de itens legados foi separada de DAN financeiro. IM-TI não exige IA para alcançar o nível máximo.

Adoção gradual e linguagem introdutória

Os mestres de junho de 2026 usavam “Iceberg Invertido” para representar uma entrada simples seguida de aprofundamento. A contribuição preservada é a **divulgação progressiva**: começar pela necessidade observada, mostrar a prática correspondente e consultar fundamentos quando forem necessários. A metáfora não estabelece uma escala científica nem exige ativar todos os módulos em uma ordem fixa.

“TI Enxuta” designa essa escolha de dimensionar registro, revisão e execução à capacidade disponível. Uma orientação recorrente pode ajudar antes de um chatbot; uma decisão registrada pode ajudar antes de um comitê formal. A possibilidade de reduzir esforço depende da aplicação e deve ser observada, sem pressupor custo zero.

O manual introdutório também usava DAA, “direcionar, agir e acompanhar”, para explicar a participação da direção. Trata-se de uma descrição didática da responsabilidade: decidir o que importa, executar o autorizado e verificar o efeito. Não substitui o ciclo ADM-Lite nem cria outro domínio. Os nomes antigos “orquestrador de valor”, “agente de mudança” e “parceiro estratégico” expressavam funções pretendidas, sem comprovar promoção de cargo ou transformação profissional.

Origem documental: mestres leigo e técnico em GP-PME/ e mestre consolidado em GP-PME antigraivty/, versões declaradas 6.0 e 5.2, de 02/06/2026. Essas contribuições são escolhas autorais, sem atribuição a uma norma externa.

Versões e direitos

GEAR 2026.10 identifica a edição editorial. Números antigos 2.0, 5.2 e 6.0 são metadados de suas respectivas versões, não versões simultâneas do produto vigente. Identificadores de software GP-PME permanecem quando necessários à compatibilidade. O histórico de origem deve acompanhar a migração de conteúdo.

Os direitos seguem LICENSE.md. Não há nova certificação, validação de marca ou concessão de direitos nesta consolidação.

Evidência acadêmica

O manuscrito mantém um protocolo prospectivo com casos sintéticos. Nenhuma simulação comprova ganho de campo. Silva, Mira da Silva e Pereira (2018), DOI [10.1109/CBI.2018.10044](https://doi.org/10.1109/CBI.2018.10044), é uma referência bibliográfica verificada; não se infere que valide GEAR. O conjunto de título, periódico e ano da referência antiga de Verdecchia não foi confirmado. A pesquisa identificou um estudo ATDx de 2022 na PeerJ e um artigo de teoria de 2021 no Journal of Systems and Software, ambos distintos da entrada antiga. Metadados e resumo não sustentam a fórmula de DAN financeiro; nenhum artigo foi adotado como substituto automático. Veja **fontes e limites**. Acesso limitado à ISO e a livros licenciados impede atribuição de detalhes não consultados.

Consulta: **Fontes e limites**. Análise aplicada: **Caso didático**.

42. Como interpretar indicadores das versões anteriores

As versões GP-PME empregavam fórmulas diferentes sob o nome DAN. Não transportar valores antigos para a edição GEAR sem recuperar definição, entradas, unidades, período e método de estimativa.

Três definições históricas

Definição encontrada	Unidade	Tratamento nesta edição
Custo de remediação / tamanho do ativo × fator de complexidade	Depende do numerador e do tamanho escolhido	Preservada como proposta histórica; não comparar horas por linha com reais por servidor
Custo anual de retrabalho atribuído à arquitetura / gasto anual de TI	Proporção no mesmo período	Indicador histórico de composição do gasto; diferente do esforço futuro de remediação
Estimativa monetária de remediação / orçamento anual de TI	Razão de valores monetários	Convenção local vigente, com escopo e premissas documentados

O exemplo histórico de 100 horas, 10.000 linhas e fator 1,5 produz 0,015 **hora por linha**, não 1,5% de risco. O fator de complexidade não foi calibrado. O exemplo de R\$ 20.000 de retrabalho em R\$ 100.000 de gasto anual produz 20% de composição estimada do gasto; não demonstra que a remediação custará esse valor.

ATDx 2020 normaliza violações por elementos de código, com análise estatística; não valida essas fórmulas financeiras. EA Debt 2019 propõe uma definição contextual de dívida. As faixas locais 0,15 e 0,35 não diagnosticam segurança, probabilidade de falha ou saúde arquitetural. **F13–F14 e limites bibliográficos.**

Benefício, custo e decisão

O rascunho de R\$ 50.000 de investimento e R\$ 25.000 de benefício anual chamava a razão 50% de ROI. Assumindo recorrência zero, doze meses estabilizados e nenhum outro custo, a razão bruta é 0,5 e o retorno líquido condicional é **-50%**. Com benefício distribuído igualmente e constante, o payback simples seria 24 meses; manter a hipótese por esse período não é resultado observado.

Refatoração, migração, automação, treinamento, licenças e transição entram na estimativa quando atribuíveis. Separar desembolso inicial, recorrência e capacidade interna; evitar contar duas vezes salários e horas ou contabilizar receita hipotética como despesa evitada. **Convenções financeiras vigentes.**

A antiga tabela DAN alta/baixa versus COT alto/baixo pode iniciar uma discussão, mas não determina investimento. Conferir obrigação, risco, dependências, alternativas, capacidade e sensibilidade. Um índice baixo não justifica adiar correção urgente; um índice alto não autoriza desativar serviço necessário.

Migrar uma série antiga

Guardar a fórmula original com os dados. Recalcular na definição vigente somente quando as entradas forem suficientes. Se o numerador mudou, iniciar nova série e indicar a quebra de comparabilidade. A pessoa responsável pela estimativa confere a conta; a autoridade decide o investimento. Ausência de orçamento impede a DAN financeira, mas não impede registrar horas e discutir o problema.

43. Glossário

Termo	Uso no GEAR
Aceite	Verificação do resultado acordado por quem responde pelo processo
ADM-Lite	Nome histórico da adaptação local de direção e revisão; não é TOGAF ADM
Canal oficial	Registro de demandas que reúne histórico e responsáveis, inclusive urgências recebidas por outros meios
CD-TI Lite	Revisão breve entre direção, TI e donos dos processos, conforme necessidade
COT	Custo de Otimização Tecnológica: investimento para uma melhoria delimitada
DAN financeiro	Estimativa de refatoração dividida pelo orçamento anual de TI; instrumento local
Domínio	Uma das três áreas essenciais: governança e direção, execução e serviços, segurança e continuidade
Fase Zero	Nome histórico do percurso inicial de adoção; nesta edição, “Primeiros 30 dias”
GEAR	Gestão, Execução, Agilidade e Risco; nome do framework, sem equivalência com quatro pilares
GP-PME / NEXUS-PME	Denominações anteriores preservadas em histórico, caminhos e identificadores de compatibilidade
IM-TI	Soma de dez práticas verificadas; instrumento local de maturidade de 0 a 10
MVP	Recorte de solução usado para testar uma hipótese; prazo e benefício dependem do escopo
NIST-Lite	Expressão histórica para seleção local de práticas inspiradas no NIST; não é perfil certificado
PRI	Plano de resposta a incidentes com contatos, alçadas, ações e recuperação
PRD	Registro de problema, escopo, restrições e critérios de verificação de uma melhoria
Proporção legada	Itens classificados como legados / itens totais; distinta de DAN financeiro
RPO	Perda de dados tolerável expressa como tempo
RTO	Tempo de recuperação tolerável para o serviço
WIP	Trabalho iniciado por executor, incluindo teste e bloqueio; limite inicial de três

As definições operacionais e suas exceções estão nos guias correspondentes. Um nome histórico não deve ser interpretado como conformidade com a referência externa.

44. Fontes e limites de uso

Consultas realizadas em **4 e 5 de outubro de 2026**, com data e recorte em cada entrada. Fontes primárias fundamentam conceitos; não demonstram efetividade do GEAR nem validam suas faixas, pesos, prazos ou fórmulas.

F01

NIST Cybersecurity Framework 2.0: Small Business Quick-Start Guide, Daniel Eliot, NIST. NIST SP 1300, publicado em 26/02/2024.

[Registro oficial](#), [DOI](#), [PDF oficial](#).

Seção consultada e limite: Resumo e pp. 2-8. Guia suplementar para pequenas organizações; não valida parâmetros do GEAR. Consulta: 04/10/2026.

F02

The NIST Cybersecurity Framework (CSF) 2.0, NIST. NIST CSWP 29, 26/02/2024.

[DOI](#), [PDF oficial](#).

Seção consultada e limite: Resumo, Executive Summary e seção 3. Resultados e perfis; não prescreve uma implementação única. Consulta: 04/10/2026.

F03

O Guia do Scrum: O Guia Definitivo para o Scrum: As Regras do Jogo, Ken Schwaber e Jeff Sutherland. Novembro de 2020; tradução brasileira distribuída no site oficial, arquivo PortugueseBR-3.0.

[Índice oficial](#), [PDF em português brasileiro](#).

Seção consultada e limite: Definição de Scrum e Scrum Team, pp. 2, 4, 6-8. Práticas inspiradas não equivalem a Scrum completo. Consulta: 04/10/2026.

F04

TOGAF, The Open Group. Página pública com apresentação da 10ª edição; a página também apresenta a versão 9.2.

[Página oficial](#).

Seção consultada e limite: Apresentação pública da 10ª edição. Capítulos detalhados redirecionaram a autenticação; ADM-Lite é local. Consulta: 04/10/2026.

F05

DORA's software delivery performance metrics, Nathen Harvey, DORA / Google Cloud. Atualizada em 05/01/2026.

[Guia oficial.](#)

Seção consultada e limite: Key insights e Common pitfalls. Cinco métricas para entrega de software; não métricas gerais de governança. Consulta: 04/10/2026.

F06

A history of DORA's software delivery metrics, Nathen Harvey, DORA / Google Cloud. Publicada e atualizada em 02/01/2026.

[Histórico oficial.](#)

Seção consultada e limite: Refining definitions e From four keys to five. Distingue recuperação de implantação com falha de MTTR geral. Consulta: 04/10/2026.

F07

Web Content Accessibility Guidelines (WCAG) 2.2, W3C. Recomendação de 12/12/2024, versão servida na consulta.

[Versão fixa, URL da versão publicada mais recente.](#)

Seção consultada e limite: Critérios 1.4.3, 1.4.10, 1.4.12, 2.1.1, 2.4.7, 2.4.11 e 2.5.8. Alvo de teste; sem declaração de conformidade. Consulta: 04/10/2026.

F08

Diátaxis, Daniele Procida. Site em evolução; data de publicação e número de versão não declarados nas páginas consultadas.

[Apresentação, Introdução de cinco minutos, Autoria e citação.](#)

Seção consultada e limite: Start here e Colophon. Orientação editorial, sem estudo de usabilidade específico do GEAR. Consulta: 04/10/2026.

F09

COBIT, ISACA. Página sobre COBIT 2019, sem data única de publicação.

[Página oficial.](#)

Seção consultada e limite: Why COBIT e Practical Guidance. Adaptação ao contexto; não se atribuem fórmulas locais à ISACA. Consulta: 04/10/2026.

F10

ITIL 4 Foundation, PeopleCert. Página específica do ITIL 4 Foundation, sem data única de publicação.

[Página oficial.](#)

Seção consultada e limite: What will you learn? e Guiding principles. Escopo ITIL 4, sem alegação sobre edição mais recente do portfólio. Consulta: 04/10/2026.

F11

Center for Internet Security. *CIS Critical Security Controls Implementation Groups*. Página institucional, sem data única declarada. [Fonte oficial](#). Seção IG1: 56 salvaguardas de higiene cibernética. Consulta: 04/10/2026. Uma seleção de quatro práticas ou dez verificações locais não equivale à implantação integral do IG1.

F12

CISA, MS-ISAC, NSA e FBI. *#StopRansomware Guide*. Guia institucional, versão consultada em 04/10/2026. [Página oficial](#). Seções sobre prevenção e resposta: backups offline e encriptados, teste regular, MFA resistente a phishing e menor privilégio. O guia não oferece garantia de proteção nem sustenta o percentual de 95% anunciado em versões históricas.

F13

Verdecchia, Roberto; Lago, Patricia; Malavolta, Ivano; Ozkaya, Ipek. *ATDx: Building an Architectural Technical Debt Index*. ENASE 2020, SciTePress, 2020, pp. 531-539. DOI [10.5220/0009577805310539](#). [Manuscrito do primeiro autor](#); [registro institucional VU](#).

Seções consultadas: §§ 2.1-2.2, 4.1.6, 4.2 e 6; páginas 2-3 e 6-8 do PDF do autor. A normalização usa violações por elementos de código e análise estatística de projetos; não orçamento de TI. O texto não fundamenta DAN financeira, faixas 0,15/0,35, COT ou ROI em PME. Consulta: 05/10/2026. Paginação do manuscrito difere do registro dos anais; não foi transposta.

F14

Hacks, Simon; Höfert, Hendrik; Salentin, Johannes; Yeong, Yoon Chow; Lichter, Horst. *Towards the Definition of Enterprise Architecture Debts*. IEEE EDOCW, 2019, pp. 9-16. DOI [10.1109/EDOCW.2019.00016](#). [Registro e versão dos autores](#); [preprint v1, 28/06/2019](#).

Seções consultadas: §§ 2, 4-7, páginas 2 e 4-7 do preprint. Propõe uma definição de dívida de arquitetura empresarial com ponderação contextual e demonstração por casos fictícios; avaliação real está fora do escopo. Não fundamenta COT, ROI, DAN financeira ou faixas para PME. Consulta: 05/10/2026. Metadados IEEE conferidos; o texto final dos anais não foi comparado integralmente ao preprint.

F15

Brasil. *Lei nº 13.709, de 14 de agosto de 2018: Lei Geral de Proteção de Dados Pessoais (LGPD)*. Texto atualizado disponibilizado pela Câmara dos Deputados. [Texto oficial](#).

Captura oficial realizada em 04/10/2026; releitura dos arts. 6º, 7º, 18, 37, 46 e 48 em 05/10/2026. Os dispositivos fundamentam princípios, hipóteses legais, direitos, registros, segurança e comunicação de incidentes. A seleção não é análise integral de conformidade, nem permite presumir enquadramento especial de uma PME. O registro local do GEAR não substitui a avaliação das obrigações aplicáveis.

F16

Autoridade Nacional de Proteção de Dados. *Comunicação de Incidentes de Segurança - CIS*. Página publicada em 23/12/2022; modificação indicada em 26/08/2026 na consulta. [Orientação oficial](#).

Consulta e captura: 04/10/2026. Perguntas 4-6: prazo geral de três dias úteis para comunicação à ANPD e aos titulares nos casos sujeitos à obrigação, ressalvado prazo em legislação específica; comunicação complementar não substitui a inicial. A página referencia a Resolução nº 15/2024, cujo texto integral não foi obtido nesta pesquisa. Marco inicial, contagem e exceções requerem conferência do ato aplicável. As regras de agentes de pequeno porte não foram verificadas integralmente; não se atribui prazo diferenciado pelo número de empregados.

Tipografia local

US Web Design System / GSA. *Public Sans*, v2.001. [Repositório oficial](#). Adobe. *Source Serif*, v4.005. [Repositório oficial](#). Consulta: 04/10/2026. Arquivos distribuídos com SIL Open Font License 1.1; versões, commits, URLs dos binários e SHA-256 registrados no manifesto de fontes que acompanha os ativos. Os arquivos não foram modificados.

Bibliografia e acesso limitado

Silva, David; Mira da Silva, Miguel; Pereira, Ruben. *Baseline Mechanisms for Enterprise Governance of IT in SMEs*. IEEE CBI, 2018, pp. 32-41. DOI [10.1109/CBI.2018.10044](https://doi.org/10.1109/CBI.2018.10044). Metadados verificados; não demonstra eficácia do GEAR.

A entrada histórica atribuída a Verdecchia em 2022 mistura um título e periódico que não foram confirmados em conjunto. Dois trabalhos reais foram identificados: *Empirical evaluation of an architectural technical debt index in the context of the Apache and ONAP ecosystems* (Verdecchia, Malavolta, Lago e Ozkaya, **PeerJ Computer Science**, 8:e833, 07/02/2022), DOI [10.7717/peerj-cs.833](https://doi.org/10.7717/peerj-cs.833); e *Building and evaluating a theory of architectural technical debt in software-intensive systems* (Verdecchia, Kruchten, Lago e Malavolta, **Journal of Systems and Software**, 176:110925, junho de 2021), DOI [10.1016/j.jss.2021.110925](https://doi.org/10.1016/j.jss.2021.110925).

Fontes consultadas em 04/10/2026: registros depositados pelas editoras no Crossref, 2022 e 2021. Foram verificados metadados e resumo do artigo de 2022, que descreve ATDx baseado em SonarQube nos ecossistemas Apache e ONAP; somente metadados do artigo de 2021. O texto integral não foi acessado. Nenhum foi usado como substituição automática da referência antiga nem valida a fórmula financeira de DAN ou o ROI do GEAR. A similaridade de títulos não comprova qual documento originou a entrada histórica.

O catálogo/OBP ISO retornou bloqueio de acesso; capítulos TOGAF exigiram autenticação. Não atribuir detalhes dessas normas ou de livros licenciados como se tivessem sido lidos. As sínteses históricas do acervo são material de trabalho, não substitutos dos documentos originais.